Divisi Villa Management & Agency — Bali & Yogyakarta

Project Villa Agency — Dokumen Update Lengkap A–Z

Reservation & Operations Control Plane

Dokumen kerja internal · dirender dari `docs/PROJECT_VILLA_AGENCY_A-Z.md` · 144,642 karakter

Nama sistem: Villa Agency OS (Villa Management & Agency)
Tanggal dokumen: 12 November 2026 · **Pemilik:** Owner (Mas Anas) · **Disusun oleh:** divisi Villa Management & Agency
Posisi repo (potret, bukan angka hidup): `~/villa-agency-os` pada commit `2cb0696` — 181 commit (pertama 2026-09-21), 375 berkas ter-track, 58 modul `src/*.py` (±52.924 baris), 102 berkas `test_*.py` (104 berkas `.py` di `tests/` termasuk `conftest.py` dan `seed_support.py`), 68 berkas ADR (ADR-0068 ditambahkan 2026-11-13 setelah dokumen ini disusun). **Hari ini (2026-11-14, `master` = `8d9fca9` + patch ADR-0069):** 212 komit, 402 berkas ter-track, 112 berkas `test_*.py`, 4.009 tes lulus (`make check` rc=0).

> **Cara membaca dokumen ini.** Dokumen ini adalah konsolidasi *bertanggal* dari seluruh sumber resmi di repo (Charter, Peta Status & Gap, Panduan Alur Kerja, State Machine, Policy Matrix, Data Model, Runbook, Deployment, Tenant Setup, ADR 0001–0068, kode `src/`, skema `src/schema/`, templat, dan gerbang `make check`). Setiap fakta berasal dari berkas yang dibaca langsung pada sesi ini, bukan dari ingatan. Bila sebuah angka berasal dari potret lama, itu ditandai **[potret]** beserta tanggalnya. Bagian yang **belum ada / belum diputuskan** ditulis terang-terangan di Bab 24–26, bukan disembunyikan. Nilai kredensial (token, kata sandi, kunci) **tidak pernah** dimuat di sini; jika perlu disebut, ditulis `[REDACTED]`.
>
> **Dokumen ini bukan nasihat hukum atau pajak.** Aturan PBJT, izin pariwisata, kewajiban Rupiah, PJP, UU PDP, dan kontrak owner wajib ditinjau counsel lokal sebelum dijadikan aturan bisnis final (lihat Bab 21).

Daftar Isi

- Bagian I — Fondasi: **1** Ringkasan satu halaman · **2** Filosofi · **3** Maksud, tujuan, North Star · **4** Ruang lingkup
- Bagian II — Orang & organisasi: **5** Aktor dan peran manusia · **6** Organisasi AI Workforce (7 komponen)
- Bagian III — Arsitektur: **7** Peta sistem & struktur repo · **8** Tiga ledger & satu penulis · **9** Model data · **10** State machine booking (32 status) · **11** Hold, ketersediaan, bukti · **12** Policy sebagai data & kalkulasi quote · **13** Uang: invoice, pembayaran, rekonsiliasi, FX, settlement
- Bagian IV — Permukaan produk: **14** Situs publik (marketing) · **15** Maps & Geo · **16** Dashboard internal
- Bagian V — Alur kerja: **17** Perjalanan satu booking (A–Z) · **18** Katalog skenario (normal, pinggiran, gagal, insiden) · **19** Ritme operasional harian–bulanan
- Bagian VI — Kontrol: **20** Keamanan, privasi, audit · **21** Legal, pajak, kepatuhan · **22** Kualitas: tes, gerbang, CI
- Bagian VII — Menjalankan: **23** Deployment, tenant, skalabilitas, backup
- Bagian VIII — Status jujur: **24** Status hari ini · **25** Celah dan risiko terbuka · **26** Keputusan Owner dan langkah berikutnya
- Lampiran: **A** Glosarium · **B** Indeks 70 ADR · **C** Indeks 59 modul `src/` · **D** Migrasi, skrip, target make · **E** Apa yang diverifikasi dan apa yang dikutip · **F** Ketidakkonsistenan yang ditemukan

---

BAGIAN I — FONDASI

1. Ringkasan satu halaman

Apa ini. Villa Agency OS adalah *sistem operasi reservasi dan operasi* untuk agency villa di **Bali** dan **Yogyakarta**. Ia bukan sekadar aplikasi booking: ia mengurus tiga hal yang paling sering menimbulkan kerugian di bisnis villa —

1. **Tanggal** — siapa memakai unit mana, kapan, dan apakah benar-benar masih kosong.
2. **Uang** — berapa yang harus ditagih, sudah masuk berapa, cocok dengan invoice mana, berapa hak pemilik villa.
3. **Bukti** — siapa memutuskan apa, kapan, atas dasar data apa.

Satu kalimat arsitektur (berlaku di seluruh repo):

> AI membaca, menganalisis, merekomendasikan, dan membuat draft. Sistem deterministik memvalidasi tanggal, uang, pajak, policy, lock, status, dan izin akses. Manusia memegang keputusan berisiko.

Angka kunci (diverifikasi 2026-11-12):

Hal	Nilai	Sumber/Bukti
Status booking	32 status, 120 sisi legal dari 1.024 pasangan	`docs/BOOKING_STATE_MACHINE.md`, `src/booking_states.py`
Tabel skema awal	72 tabel (`001_initial.sql`)	dihitung ulang dengan memuat skema ke SQLite memori
Migrasi lanjutan	002 (PG) dan 003–008, 010–017 (tidak ada 009)	`ls src/schema`
Halaman dashboard	14 entri `PAGE_ROLES` (12 halaman navigasi + `case_detail` + `error`); 6 peran	`PAGE_ROLES` di `src/dashboard.py`
Rute situs publik	`/` , `/villas` , `/villas/<id>` , `/destinations/bali` , `/destinations/yogyakarta` , `/owners` , `/inquiry` , `/favicon.ico`	`src/marketing_site.py`
ADR	70 berkas (`0001` – `0070` ; 70 Accepted)	`ls docs/adr`
Tes terakhir	`make check` rc=0: **4.009 passed, 4 skipped, 4.054 subtests passed** (315,61 s)	log gerbang 2026-11-14, pohon `master` `8d9fca9` + ADR-0069
Gerbang	SECRET-SCAN 0/402, UNSAFE-SCAN 0/402, PII-SCAN 0/377, PRE-DEPLOY GATE PASS	`make check`
Properti di DB hidup	3, semuanya `geo_precision=UNKNOWN`	query baca-saja 2026-11-12

Status go-live. Preflight terakhir yang terdokumentasi berbunyi `NO-GO — 1 BLOCKING decision(s) still OPEN: D17` **[potret 2026-10-02; keadaan 2026-11-12 ada di Bab 24]**. Penahan go-live adalah *keputusan bisnis*, bukan software (“the system may be ready while the business is not”). Lihat Bab 26.

---

2. Filosofi

Filosofi di bawah ini bukan slogan; setiap butir punya penegak di kode atau tes.

2.1 Delapan prinsip yang tidak bisa ditawar

#	Prinsip	Artinya	Penegak
1	**Deterministik dulu, AI paling akhir**	Angka, tanggal, status, uang dihitung program yang hasilnya sama untuk input yang sama. AI hanya merangkai fakta ber-ID menjadi kalimat.	`quote_calculator` , `policy_engine` , `ai_gateway` , deny registry
2	**Fail-closed**	Data hilang, basi, atau timeout = `UNKNOWN` /ditolak, bukan “kira-kira tersedia”.	`availability.py` , `gates.py` , `evidence.py` , `geo.py`
3	**Satu penulis per fakta**	Hanya `ReservationKernel` yang menulis `HOLD_ACTIVE` / `CONFIRMED` / `CANCELLED` . Modul lain mengusulkan, tidak menulis.	`reservation_kernel.py` , uji statis “tidak ada modul lain memanggil `authorize` ”
4	**Policy adalah data, bukan prompt**	Deposit, pajak, pembatalan, mata uang disimpan sebagai versi berversi per properti; booking menyimpan *snapshot*.	`policy_engine.py` , `policy_versions`
5	**Tiga ledger dipisah**	Inventaris, Uang, Bukti/Komunikasi tidak boleh bercampur.	skema `001_initial.sql`
6	**Bukti sebelum klaim**	Tidak ada tindakan “selesai” tanpa jejak yang bisa ditelusuri dari satu nomor kasus.	`audit.py` (hash chain), `booking_state_events` , `anchors.py`
7	**Manusia memegang keputusan berisiko**	Uang keluar = dua persetujuan; pemohon ≠ penyetuju; refund, payout, ganti rekening, relokasi, pengecualian policy, dynamic pricing, penghapusan data tamu perlu manusia.	`approvals.py` (dual control), `ai_service.py` deny registry
8	**Keamanan, safety, privasi lebih dulu dari kecepatan**	Ditegaskan sebagai prinsip Owner (ADR-0040): setiap aksi dinilai dampak keamanannya dulu.	`gates.py` , `secret_scan.sh` , `unsafe_config_scan.sh` , `identity.py`

2.2 Lima ketidaksamaan yang dijaga kode (jangan pernah dianggap sama)

Tidak sama dengan	Contoh	Ditegakkan di
`HOLD_REQUESTED` ≠ `HOLD_CONFIRMED`	menitip permintaan tahan ke villa ≠ villa sudah menahan	`hold_states.py`, `reservation_kernel.py`
`AI_EXTRACTED` ≠ `VERIFIED`	angka yang dibaca AI dari kontrak ≠ angka yang diverifikasi manusia	`supplier_route.py`
`SOURCE_UNAVAILABLE` ≠ `NOT_AVAILABLE`	sumber ketersediaan tidak bisa dihubungi ≠ unit memang tidak tersedia	`crm.py`, `evidence.py`
Payment reported ≠ *funds received*	tamu bilang sudah transfer ≠ dana tercatat masuk	rekonsiliasi `MISSING_SETTLEMENT`, `UNVERIFIED_WEBHOOK` (`payments.py`)
`DEPOSIT_PAID` ≠ `CONFIRMED`	uang masuk ≠ villa sudah memblokir tanggal	`booking_states.py` (guard bukti)

2.3 Kenapa “modular monolith”, bukan microservices

Anggaran kompleksitas dibatasi sengaja: **modular monolith + SQLite (dev/uji) / PostgreSQL (target produksi) + penyimpanan objek + worker latar**. *Bukan* microservices, *bukan* Kafka, *bukan* framework multi-agent besar (ADR-0001, ADR-0004, Charter §4). Alasannya jujur: pilot 10–20 properti dan satu tim kecil; kerumitan terdistribusi menambah mode gagal lebih cepat daripada menambah nilai. Konsekuensinya: kode `src/` memakai **Python stdlib saja** (tanpa dependensi eksternal) — Bab 20 dan 22.

2.4 Disiplin kerja yang dipakai membangun (metode ilmiah)

- **Falsification-first:** klaim hanya sah bila bisa dibuktikan salah; “confirmed” berarti *belum terfalsifikasi*.
- **Root cause sebelum solusi** (KT IS/IS NOT, 8D); workaround ≠ perbaikan.
- **Success criteria sebelum aksi**; satu perubahan → ukur → lanjut.
- **Kontrol negatif:** gerbang keamanan diuji dengan kasus yang *harus* ditangkap (contoh: `tests/test_secret_scan.py` menanam kredensial palsu dan memastikan gerbang gagal). Gerbang yang hijau tapi buta adalah kegagalan (kasus nyata 2026-11-12, Lampiran E).
- **Temuan negatif juga temuan.** Dokumen status (`STATUS_AND_GAP_MAP.md`) sengaja memuat “apa yang belum OK”.

---

3. Maksud, tujuan, dan North Star

3.1 Maksud

Membangun **Reservation & Operations Control Plane** untuk agency villa: satu tempat di mana permintaan tamu, ketersediaan, penawaran, uang, dokumen, tugas lapangan, insiden, dan laporan owner tercatat dengan bukti — sehingga agency bisa menambah villa bertahap *tanpa pekerjaan bergantung pada satu orang*.

3.2 North Star (Charter §1; SOUL divisi)

1. **0 double booking** dan **0 konfirmasi dari ketersediaan yang tidak terverifikasi**.
2. Setiap angka di quote, invoice, dan laporan owner **reproducible** dari input bertanggal.
3. AI mempercepat respons (ekstraksi, pencarian, draft) **tanpa** wewenang menetapkan status, harga, atau kepastian booking.
4. Rekonsiliasi pembayaran **≥ 99%**, dan 100% sisa selisih punya pemilik kasus dan batas waktu.
5. **100% booking** punya policy snapshot + evidence + audit trail. **0 unsupported material claim** dari AI.

Ukuran keberhasilan **bukan** “jumlah villa” atau “jumlah chat terbalas otomatis”.

3.3 Metrik sukses awal (Charter §5 — baseline dulu, target kemudian)

Kategori	Metrik	Target awal
Reliability	Double booking	0 / bulan
Reliability	Quote error	< 1%
Reliability	False availability yang tidak dieskalasi	0
Financial	Payment reconciliation match rate	≥ 99%
Financial	Unmatched payment diselesaikan	< 48 jam
Speed	First response (jam operasional)	< 15 menit
Speed	Jawaban ketersediaan / quote awal	< 2 jam / < 4 jam
Service	Komplain kritis direspons / diselesaikan	< 1 jam / < 24 jam
AI governance	Unsupported claim rate	0 ditoleransi
AI governance	PII incident	0

Baseline *conversion funnel* (inquiry → qualified → quote → hold → paid → confirmed) diukur **4–6 minggu pertama per kanal** sebelum target ditetapkan. Catatan: angka SLA di atas adalah target Charter; SLA operasional yang berlaku sudah dikunci di keputusan D4 (`OPERATIONS_RUNBOOK.md` §13.4).

3.4 Peruntukan (untuk siapa sistem ini)

Pengguna	Mendapat apa
Tamu	Jawaban cepat, harga transparan, status jelas, peta area tanpa membocorkan alamat privat
Owner / pemilik villa	Booking, laporan, settlement yang bisa ditelusuri
Staf agency (reservasi, operasi, keuangan, GM)	Antrean kerja, SLA, approval, jejak audit
Agency pembeli lisensi	Platform yang dijual **per agency** (ADR-0037): setiap pengaturan milik tenant diisi tenant sendiri

---

4. Ruang lingkup

4.1 Pilot (Charter §2)

Aspek	Keputusan
Wilayah	Bali + Yogyakarta
Properti pilot	**10–20** (usulan kerja; jumlah final = keputusan Owner, D5/D2)
Model bisnis	Hybrid per properti: `AGENCY_COMMISSION`, `FULL_MANAGEMENT`, `HYBRID`
Kanal masuk	Situs web, email, dashboard internal, WhatsApp Business resmi
Kanal bayar	Hosted payment page PSP berlisensi PJP; **tidak ada data kartu di sistem**
Mode AI	Human-supervised; *shadow mode* sebelum auto-send terbatas
Multi-tenant SaaS penuh	Di luar MVP (namun ADR-0037 sudah menetapkan *platform dijual per agency*)

4.2 Di luar lingkup MVP (eksplisit)

Microservices · Kafka · voice bot otonom · custody dana owner · scraping OTA · otomasi WhatsApp personal · dynamic pricing otonom.

4.3 Fase produk (Charter §4, dengan status terkini)

Fase	Isi	Status
0	Charter, batas legal, contract pack, policy matrix, state machine, klasifikasi data	**DONE**
1	Reservation Kernel: model transaksional, proteksi overlap, transisi eksplisit, policy + quote calculator, audit append-only	**Selesai di kode**
2	Case management, intake terstruktur, matching yang bisa dijelaskan, approval queue, draft pesan	**Selesai di kode**
3	Invoice, hosted payment, webhook idempoten + rekonsiliasi, hold timer, dokumen, ops task, playbook insiden	**Selesai di kode**
4	Adapter kanal resmi, dashboard internal, shadow-mode evaluation, bukti go-live	**Selesai di kode** (tersisa halaman KPI + bukti go-live end-to-end menurut peta status 2026-10-03)
AI Workforce	7 komponen AI (Bab 6)	**Sebagian** — 5 dari 7 ada intinya

Rencana rinci fase 2–4 ada di `docs/PHASE2_TO_4_EXECUTION_PLAN.md` (definisi “siap deploy”, kontrak antarmuka beku, gerbang deploy).

BAGIAN II — ORANG & ORGANISASI

5. Aktor dan peran manusia

5.1 Prinsip: peran adalah akuntabilitas, bukan sekadar izin

Keputusan D3 (ADR-0035, direkonsiliasi 2026-10-02): peran manusia di dokumen organisasi Owner diadopsi **semua**, karena menamai peran tidak menambah risiko — yang menambah risiko adalah *wewenang tanpa pengawas*. Kosakata peran kini punya **satu rumah**: `src/roles.py` (`approvals.ROLE_RANK` adalah `roles.ROLE_RANK`; nama lama tetap bisa dibaca untuk baris historis; `gm` masuk tangga di rank 4). Peran per tenant dapat diganti namanya lewat `src/agency_roles.py` + `scripts/manage_roles.py` (8 peran cetak biru ter-seed; peran boleh dinonaktifkan; pemegang peran = rujukan tanpa nama orang; wewenang selalu dibaca dari cetak biru sehingga tenant **tidak bisa menaikkan wewenang** atau menghidupkan lagi peran yang dilarang bagi "pembuat AI").

5.2 Peta peran manusia (dari Peta Status & Gap §4.1 [potret 2026-10-02])

Peran manusia	Setara di spec §18	Catatan
Owner / Shareholders	Owner/Director	Boleh satu orang dengan GM
General Manager / CEO	(tidak ada di §18)	Boleh satu orang dengan Owner sampai bisnis berkembang
Commercial & Marketing Manager	(tidak ada di §18)	Diadopsi
Partnership Manager	Villa/Contract Admin	**Manusia, bukan agent**
Operations / Reservation Manager	Reservation Manager + Operations Manager	Diadopsi
Reservation Agent	Reservation Agent	Staf di bawah Ops/Res Manager
Finance & Accounting Manager	Finance Manager	Diadopsi
Finance Staff	Finance Staff	**Wajib terpisah** dari Finance Manager
Revenue Manager (atau GM bila ramping)	(tidak ada di §18)	Boleh dipegang GM
Technology / Security	System Admin	**Nol wewenang bisnis/finansial**
Legal / Compliance	(tidak ada di §18)	Boleh pihak eksternal
Guest Service	Guest Service	Diadopsi
Auditor	Auditor	**Read-only**
(non-manusia) AI Service, System Service	—	`src/ai_service.py`

Yang tidak boleh disatukan (kontrol, bukan preferensi): Finance Staff ≠ Finance Manager · Reservation Agent ≠ Reservation Manager (untuk diskon di luar policy) · System Admin tanpa wewenang uang · Auditor read-only.

5.3 Peran yang dikenal dashboard (enam peran, bukan enam belas)

Dashboard (`src/dashboard.py`) memetakan peran sistem ke peran halaman (`PAGE_ROLE_BY_CANONICAL`, dibaca langsung dari kode 2026-11-12):

Peran sistem	Peran halaman dashboard
`owner`	`owner`
`gm`	`gm`
`finance_manager`	`finance`
`reservation_manager`	`operations`
`reservation_agent`	`reservation`
`auditor`	`auditor`

Peran yang berwenang menulis lewat dashboard (`WRITE_ROLES`): `reservation`, `operations`, `finance`, `owner`, `gm`. Peran yang boleh melihat data tamu (`PII_ROLES`, ekspor/halaman PII): `operations`, `finance`. **Auditor tidak masuk** keduanya: auditor melihat, tidak mengambil.

5.4 Siapa boleh melakukan apa (ringkasan Runbook §0)

Peran	Melihat	Boleh memutuskan
`reservation`	kasus, inventory, properti	transisi kasus, hold, quote, kirim draft yang sudah disetujui
`finance`	keuangan, invoice, rekonsiliasi	mencocokkan pembayaran, menagih, mengusulkan refund
`operations`	operasi, tugas, insiden	menyelesaikan tugas, mencatat insiden, menjalankan playbook
`owner`	semua	approval akhir atas uang, pengecualian policy, relokasi, perubahan rekening
`auditor`	audit & kepatuhan (read-only)	tidak ada keputusan operasional

Dua aturan yang tidak bisa dinegosiasikan, ditegakkan modul `approvals`, bukan kebiasaan:

1. **Pemohon tidak boleh menyetujui permintaannya sendiri.**

2. **Aksi uang/legal butuh dua penyetuju berbeda** (dual control). Status approval diturunkan dari log keputusan — mengubah kolom status langsung **tidak** mengubah kenyataan.

5.5 Siapa yang memegang apa saat ini (keputusan Owner 2026-10-02)

Fungsi	Pemegang
Teknologi & keamanan (on-call, uji restore)	**Mr. TS** (Technology-Security Manager), eskalasi ke **Mr. CEO**
Persetujuan "naik kelas" pegawai AI	**GM/CEO**
Penerbitan anker audit	akun milik Owner (bukan akun server)
Pemegang kemampuan `ai.control` (tombol operator AI)	Owner + Technology-Security Manager

Nama orang untuk peran lain: **belum diisi** (Peta Status §4.1 — "saya tidak akan mengarang nama"). Nomor kontak dan jam layanan di Runbook §12 masih `[ISI]`.

5.6 MFA

Kebijakan `security.mfa.required_roles` versi 2 = **owner, finance, gm** (keputusan Owner 2026-10-02). TOTP diimplementasi stdlib (`src/totp.py`, RFC 6238/4226); sesi, enrolment, dan step-up di `src/identity.py` (ADR-0005). Detail di Bab 20.

---

6. Organisasi AI Workforce (7 komponen)

6.1 Aturan induk

- Hanya ada **enam kotak agent** (+1 tambahan Owner): worker `*-Wxx` **bukan** agent baru. Memperbanyak agent otonom dilarang oleh dokumen organisasi AI (§2A.7, §20.1).
- Partnership, GM, Owner, Finance Authority, Legal, Security adalah **MANUSIA** (§21).
- **Hub-and-spoke:** agent tidak bebas memanggil agent lain. Semua melalui Control Tower → policy check → izin tool → layanan deterministik → hasil terstruktur.
- Hanya satu pintu untuk setiap aksi AI: `src/ai_gateway.py` (tangga §17 menentukan seberapa lebar pintu terbuka). Uji statis menjaga bahwa **tidak ada modul lain** memanggil `authorize`.

6.2 Tujuh komponen dan statusnya

Sumber: Peta Status & Gap §3.1/§5.1 **[potret 2026-10-07]** dan `docs/AI_WORKFORCE_TRACEABILITY.md`. Berkas kode dikonfirmasi ada pada `ls src` 2026-11-12.

#	Komponen	Worker (kode)	Pemilik manusia	Kode	Status
1	**AI Control Tower**	CT-W01…W10 (router, workflow, SLA, exception, escalation, health, retry, notif, budget)	General Manager	`src/control_tower.py`	🟡 inti: tabel `ROUTES`, `UnroutableEvent` (tujuan tak dikenal ditolak, tak ditebak), eskalasi `ai.escalation.raised`; tool *dideklarasikan, tidak didaftarkan* (ADR-0061 opsi B). Worker CT-W01…W10 belum
2	**Commercial AI**	COM-W01…W11	Commercial & Marketing Manager	—	⚠️ belum ada
3	**AI Reservation Service**	RES-W01…W11	Operations / Reservation Manager	`src/reservation_service.py`, `src/reservation_workers.py`, `src/ai_gateway.py`	✅ lengkap 2026-10-03; tersisa halaman KPI + bukti go-live end-to-end
4	**Operations AI**	OPS-W01…W10	Operations Manager	`src/operations_agent.py`	🟡 inti baca-saja; sisa OPS-W04 (booking QC), OPS-W09 (comm QC), OPS-W10 (SOP store)
5	**Finance Admin AI**	FIN-W01…W11	Finance & Accounting Manager	`src/finance_admin.py`	🟡 inti baca-saja (AR aging, AP, due monitor, eksepsi, kas/eksposur, KPI §11); sisa FIN-W03/05/08/09
6	**Revenue & BI AI**	RBI-W01…W12 (nama kanonik ADR-0064)	Revenue Manager / GM	`src/revenue_bi_agent.py`	🟡 ±25%: slice 1 (M1/M2/M3/M6/M8/M9) baca-saja; slice 2–5 belum
7	**Security & Privacy Warden**	—	Technology/Security	—	⚠️ belum ada kodenya; ditetapkan Owner 2026-10-02 (ADR-0039)

Ringkas: **5 dari 7** punya inti di kode; 2 (Commercial, Security & Privacy Warden) belum. Nama kanonik RBI-W01…W12: `revenue_kpi, conversion, pace_leadtime, demand_intel, pricing_intel, villa_performance, partner_performance, channel_performance, forecast, margin, anomaly, exec_report`.

6.3 Pegawai AI ke-7 — Security & Privacy Warden (ADR-0039)

Ditetapkan Owner 2026-10-02. ADR memuat: matriks wewenang ("boleh sendiri" vs "wajib persetujuan manusia"), tingkat kegawatan S1–S4, dan 4 entri daftar larangan yang **menunggu persetujuan Owner**.

6.4 Delapan rung tangga percakapan §13 (AI Reservation Service)

`src/reservation_service.py`: ledger percakapan berisolasi (satu percakapan = satu baris, membawa referensi bukan salinan — ADR-0042), tangga §13 (8 rung), kosakata eskalasi **tertutup** (ADR-0044), ambang keyakinan *deny-first*, paket handoff berdigest, handoff hanya ke peran yang berisi orang. **Eskalasi membisukan AI sebelum manusia tiba** (ADR-0043). Tabel yang menopang: migrasi `012_reservation_service.sql`.

6.5 Sebelas worker Reservation (RES-W01…W11)

Dijalankan lewat `ai_gateway` + `src/reservation_workers.py` ("the AI employee's hands, and the only ones it has"; ADR-0045: *worker menjaga thread, mengetuk pintu, baru mendelegasikan*):

Worker	Fungsi	Catatan batas
RES-W01	inquiry	intake terstruktur
RES-W02	matching	opsi, bukan keputusan
RES-W03	availability	membaca status, tidak menulis
RES-W04	pricing	memakai `reservation_kernel.quote_stay` — mengumpulkan aturan yang ada, **tidak menulis** (ADR-0046)
RES-W05	versi penawaran	satu tindakan `quotation.send` (MEDIUM)
RES-W06	follow-up	rutin = *task*, bukan hold (ADR-0047)
RES-W07	hold	hold adalah slot
RES-W08	status booking	"status adalah jawaban" (ADR-0048)
RES-W09	amend/cancel assist	menjawab dan merutekan; **manusia memutuskan** (ADR-0049)
RES-W10	pre-arrival	merangkai apa yang dikirim manusia (ADR-0051)
RES-W11	handoff	satu gestur, dua rung, tanpa pintu §56 (ADR-0053)

Tidak ada tool write dari jalur bahasa: AI **tidak** punya akses membuat/mengubah booking, harga, refund, atau pesan keluar tanpa approval manusia.

6.6 Tangga kill switch (§17)

Status	Perilaku	Ada di kode
ACTIVE	normal	✅
SUSPENDED	per-principal	✅ (`ai_service.py`)
DEGRADED	hanya alat tingkat LOW; menolak MEDIUM walau policy mengizinkan	✅
READ_ONLY	hanya alat berefek READ	✅
DISABLED / RETIRED	RETIRED terminal	✅

Circuit breaker: `AiGateway.record_failure` — 3 kegagalan berturut dalam 15 menit → `READ_ONLY` otomatis + insiden SEV3. Tombol operator: `scripts/ai_mode.py`.

6.7 Identitas AI dan registri larangan (ADR-0018)

`src/ai_service.py`: tier `LOW/MEDIUM/HIGH`, status `ACTIVE/SUSPENDED/RETIRED`, deny registry kebijakan `security.ai.denied_actions`. Larangan mutlak yang sudah ditegakkan di kode:

Larangan	Penegak
AI menyetujui/mengeksekusi pembayaran	identitas `ai_service` + deny registry
AI mengubah tujuan bank/crypto	idem
AI menandai dana belum terverifikasi sebagai diterima	jenis rekonsiliasi `UNVERIFIED_WEBHOOK`
AI melewati maker-checker	`approvals.py` dual control
PAN/CVV masuk konteks AI atau storage biasa	`CARD_DATA_FORBIDDEN` + gate `unsafe_config_scan`

6.8 Kenaikan kelas lewat pengukuran (D7 / ADR-0038 / ADR-0058)

Pegawai AI wajib melewati **≥ 100 kasus** dalam *shadow mode* dengan **kecocokan ≥ 95%** dan **0 klaim tanpa bukti** sebelum boleh bertindak nyata. Penyetuju kenaikan: **GM/CEO**. Setelah naik kelas, bila kecocokan turun **< 90% dalam 50 tindakan terakhir**, atau satu klaim tanpa bukti sampai ke tamu, pegawai itu **otomatis kembali ke mode bayangan** dan kegawatan dilaporkan ke GM/CEO & Owner. Pengukuran: `src/shadow_eval.py` (ambang jadi *policy key*, modul hanya mengukur — ADR-0058; migrasi `015_shadow_bars.sql`). KPI Agent 3: `src/reservation_kpi.py` + `scripts/reservation_kpi.py` (ADR-0057: hitungan atas fakta tercatat, tanpa data person).

6.9 Aturan pemakaian AI yang paling sering dilanggar (Data Classification §3)

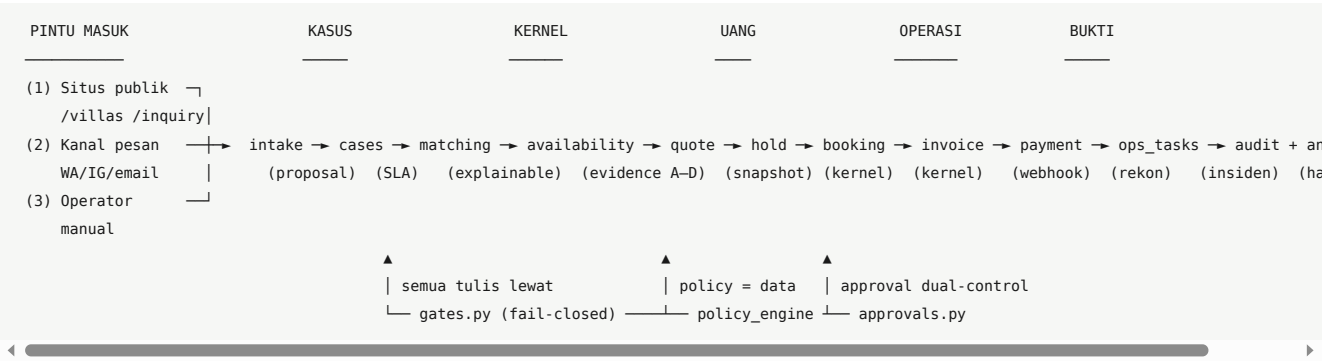
1. **Pseudonimisasi wajib:** ke LLM dikirim `guest_ref` (ID acak) + atribut yang benar-benar perlu; nama/telepon/email/paspor diganti token.
2. **Konten eksternal = data, bukan instruksi** (email, PDF, WhatsApp, halaman web masuk sebagai data tak dipercaya).

3. **Tidak ada tool write dari jalur bahasa.**
4. **Tidak ada klaim tanpa ID:** setiap fakta di balasan AI merujuk record; tanpa rujukan → kalimat tidak boleh dikirim.
5. **Angka dihitung tool, bukan model.**
6. **Confidence ≠ kepastian:** dilarang menyimpulkan “tersedia” dari data level C/D.
7. **Prompt berisi P2/P3 tidak disimpan** ke log/tracing pihak ketiga.
8. **Opt-out** penggunaan data untuk pelatihan harus dihormati dan tersimpan sebagai atribut `guest_ref`.

BAGIAN III — ARSITEKTUR

7. Peta sistem dan struktur repo

7.1 Peta besar (satu arah)



Tiga pintu masuk bermuara ke satu tempat: **kasus (case)**. Situs publik tidak pernah menulis harga atau mengunci tanggal; ia hanya membaca data publik dan mengirim *inquiry* sebagai kasus baru (Panduan Alur Kerja §3).

7.2 Dua proses yang berjalan (permukaan produk)

Proses	Alamat	Peran	Unit systemd (user)
Situs publik (marketing)	`127.0.0.1:8090`	Tamu: katalog villa, detail villa, destinasi, formulir *inquiry*, peta area. Hanya baca data publik. Berjalan di belakang reverse proxy; alamat tamu hanya dipercaya dari hop proxy sendiri (ADR-0067).	`deploy/systemd-user/villa-marketing.service`
Dashboard internal	`127.0.0.1:8085`	Staf: 12 halaman utama (+ detail kasus dan halaman error), 6 peran, jalur tulis hanya untuk peran penulis. Header kredensial mesin `X-Dashboard-Token`; sesi operator + MFA untuk manusia (Bab 16, 20).	`deploy/systemd-user/villa-dashboard.service`

Keduanya **loopback saja**. Membuka dashboard ke internet butuh lapisan login tambahan yang belum dibangun (Bab 25). Pemisahan dua permukaan ini diputuskan di `docs/PRODUCT_SURFACE_SEPARATION_2026-10-05.md`.

7.3 Struktur direktori repo `~/villa-agency-os` (hasil baca 2026-11-12)

Lokasi	Isi	Jumlah (diukur)
`src/`	Seluruh logika domain, Python stdlib saja	59 modul `.py`, 54.029 baris (diukur 2026-11-13; potret `2cb0696`: 58 / 52.924)
`src/schema/`	Skema SQLite + twin PostgreSQL + migrasi	`001_initial.sql`, `001_initial.pg.sql`, `002_pg_range_exclusions.pg.sql`, migrasi `003` – `008`, `010` – `017` (tidak ada `009`)
`tests/`	Uji otomatis (pytest + subtests)	**112** berkas `test_*.py` (59.343 baris) + `conftest.py`, `seed_support.py`, dan dua helper lain → seluruh `.py` di `tests/`: **116 berkas / 59.748 baris**. Diukur 2026-11-13 pada `master` `95ce7d3`; pada potret `2cb0696` terukur 102 / 57.649 (seluruh `.py`: 104 / 57.881)
`docs/`	Dokumen kerja, ADR, keamanan, laporan desain	29 berkas `.md` di akar `docs/` (42 entri termasuk HTML/PDF dan subfolder), `docs/adr/` (70 ADR), `docs/security/`
`scripts/`	CLI operator, gerbang, utilitas	22 berkas
`templates/`	HTML dashboard (`base`, `error`, dan halaman), `templates/marketing/` (9 berkas), `templates/messages/id-ID.json` (templat pesan)	15 `.html` dashboard
`deploy/systemd-user/`	Dua unit layanan	2 berkas
`demo/`	Demo pelanggan (HTML, video mock)	—
`reports/`	`final-report.md`, `release-quality-gate.md`, `security-gate.md`, `BUILD_STATUS_2026-09-22.md`, `perf-baseline-2026-10-25.txt`	5 berkas
`Makefile`, `README.md`	Gerbang dan pintu masuk	—
`data/villa.db`	Database SQLite hidup	73 tabel

7.4 Sumber kebenaran per hal (agar tidak ada dua versi)

Hal	Rumah tunggal	Dijaga oleh
32 status booking	DDL `bookings.status CHECK` di `001_initial.sql`	`states_from_schema()`, `tests/test_booking_states.py`

Hal	Rumah tunggal	Dijaga oleh
Status yang menempati slot	indeks parsial `uq_bookings_active_slot`	`occupying_states_from_schema()`
Kosakata peran manusia	`src/roles.py`	`tests/test_roles.py`
Angka bisnis	`policy_versions` / `PolicyVersion` (`policy_engine.py`)	katalog policy 25/25 key
Kosakata hold	`src/hold_states.py`	uji state hold
Skema SQLite ⇄ PostgreSQL	`001_initial.sql` ⇄ `001_initial.pg.sql`	`scripts/generate_pg_twin.py --check`, `make schema-parity`, `make pg-twin`

8. Tiga ledger dan satu penulis

8.1 Tiga ledger yang tidak boleh bercampur

Ledger	Isi	Tabel inti (contoh)
Inventory Ledger	unit, tanggal, hold, blok, konflik	`units`, `holds`, `bookings`, `booking_state_events`, `availability_checks`, `availability_evidence`, `availability_check_events`, `hold_extension_requests`
Money Ledger	quote, invoice, pembayaran, refund, fee, pajak, settlement	`quotes`, `quotation_versions`, `quotation_snapshots`, `invoices`, `invoice_lines`, `payments`, `payment_events`, `ledger_entries`, `reconciliation_cases`, `deposit_resolutions`, `supplier_settlements`
Evidence & Communication Ledger	pesan, bukti availability, versi policy, approval, tool call, aktor, waktu	`case_messages`, `case_events`, `evidence_objects`, `evidence_events`, `evidence_access_grants`, `approval_requests`, `approval_decisions`, `audit_events`, `ai_conversation_events`, `message_drafts`

8.2 Reservation Kernel: satu-satunya penulis

`ReservationKernel` (`src/reservation_kernel.py`, 3.194 baris) adalah satu-satunya penulis `HOLD_ACTIVE`, `CONFIRMED`, dan `CANCELLED`. Prasyarat setiap tulisan: **transaksi DB, kunci inventaris, constraint overlap, idempotency key**. Freshness timestamp saja *tidak cukup* mencegah double booking.

Pertahanan overlap berlapis tiga (ADR-0002, State Machine §6):

1. **Pemeriksaan kernel** (kode) sebelum menulis.
2. **Indeks parsial SQLite** `uq_bookings_active_slot` — unit + tanggal unik untuk status yang menempati slot.
3. **`ex_bookings_no_overlap`** di PostgreSQL (migrasi `002_pg_range_exclusions.pg.sql`) — exclusion constraint rentang tanggal.

Untuk jalur AI, pintu tunggalnya `src/ai_gateway.py`: tidak ada modul lain yang boleh memanggil `authorize`, dijaga uji statis (Peta Status & Gap §6, langkah 3).

9. Model data

9.1 Ukuran

- Model skema (`schema_loader.parse_schema_model('sqlite')`, 2026-11-12): **72 tabel**, 62 indeks, 64 trigger, 106 enum, 77 `INSERT` seed.
- DB hidup `data/villa.db` (dibaca read-only 2026-11-12): **73 tabel** = 72 tabel model + `schema_migrations` (pembukuan migrasi 003–017; `schema_meta` hanya mencatat `001_initial`); 183 indeks (122 di antaranya `sqlite_autoindex` otomatis dari UNIQUE/PK), 64 trigger. Seluruh 73 nama tabel di §9.2 dicocokkan dengan `sqlite_master`: tidak ada yang kurang atau lebih.
- Isi DB hidup saat dicek: 3 properti, 3 unit, 22 baris `audit_events`, 0 booking. Jadi belum ada booking nyata di DB ini.

9.2 Kelompok tabel (73 tabel; pengelompokan oleh penulis, nama dari `sqlite_master`)

Kelompok	Tabel
Agency & tenant	`agencies`, `agency_settings`, `agency_roles`, `agency_role_holders`
Properti & pasokan	`properties`, `units`, `suppliers`, `villa_supplier_relationships`, `contract_versions`, `rate_cards`, `rate_versions`, `rate_seasons`
Policy	`policy_defs`, `policy_versions`, `policy_revisions`
Tamu & kasus	`guests`, `cases`, `case_messages`, `case_events`, `intake_fields`, `intake_proposals`, `inquiry_requirements`
Pencocokan	`match_runs`, `match_candidates`, `option_sets`, `option_set_items`, `option_set_presentations`
Ketersediaan & hold	`availability_checks`, `availability_check_events`, `availability_evidence`, `holds`, `hold_extension_requests`
Penawaran	`quotes`, `quotation_versions`, `quotation_snapshots`, `quotation_acceptances`
Booking	`bookings`, `booking_state_events`, `idempotency_keys`
Uang	`invoices`, `invoice_lines`, `payments`, `payment_events`, `ledger_entries`, `reconciliation_cases`, `deposit_resolutions`, `supplier_settlements`
Bukti & dokumen	`documents`, `evidence_objects`, `evidence_events`, `evidence_access_grants`

Kelompok	Tabel
Persetujuan & audit	`approval_requests`, `approval_decisions`, `audit_events`, `auth_events`
Identitas & sesi	`auth_sessions`, `mfa_factors`
Operasi	`ops_tasks`, `incidents`, `incident_steps`, `sla_breaches`, `exception_fingerprints`
Outbox & integrasi	`outbox_events`, `outbox_deliveries`, `integration_inbox`, `message_drafts`
AI	`ai_principals`, `ai_principal_events`, `ai_tools`, `ai_conversations`, `ai_conversation_events`
Meta	`schema_meta`, `schema_migrations`

9.3 Aturan model data

1. **Append-only** untuk jurnal (`booking_state_events`, `audit_events`, `payment_events`, `evidence_events`): `(booking_id, seq)` unik; menulis ulang ditolak oleh database, bukan disaring di kode. Trigger (64 buah) menegakkan ketidakbisaan ubah, termasuk isi surat outbox.
2. **Uang = bilangan bulat satuan terkecil** (rupiah utuh, sen untuk USD). Tidak ada float. Perhitungan memakai `Decimal`, hasil dibulatkan sekali dengan aturan tercatat.
3. **Satu `agency_id` di semua baris tenant** — isolasi per agency adalah invarian, bukan fitur.
4. **Waktu selalu sadar zona** (ISO-8601, `+00:00`); waktu naif ditolak. Zona properti: `Asia/Makassar` (Bali), `Asia/Jakarta` (Yogyakarta).
5. **Identifier**: format rujukan manusiawi di `references.py` (Master Spec Lampiran B, ADR-0014); id yang dicetak tidak boleh berbentuk identitas (ADR-0062, ADR-0063).
6. **Migrasi**: berjalan lewat `scripts/apply_migrations.py` dengan `VILLA_DB` wajib diset eksplisit; selalu `--dry-run` dulu.

9.4 Migrasi skema (src/schema/)

No	Berkas	Isi
001	`001_initial.sql` / `001_initial.pg.sql`	Skema awal SQLite + twin PostgreSQL
002	`002_pg_range_exclusions.pg.sql`	Exclusion constraint overlap (PG saja)
003	`003_policy_catalogue_and_deny_registry.sql`	Katalog policy + registri larangan AI
004	`004_currency_aware_margin_floor.sql`	Batas margin sadar mata uang
005	`005_fx_rate_max_age_hours.sql`	Umur maksimum kurs (jam)
006	`006_outbox_and_integration_inbox.sql`	Outbox transaksional + inbox integrasi
007	`007_exception_fingerprints.sql`	Sidik jari eksepsi (satu insiden + penghitung)
008	`008_agency_settings.sql`	Setelan milik tenant
009	*(tidak ada)*	Nomor dilewati
010	`010_agency_roles.sql`	Peran per tenant
011	`011_ai_ladder.sql`	Tangga AI
012	`012_reservation_service.sql`	Ledger percakapan AI Reservation Service
013	`013_deposit_resolutions.sql`	Resolusi deposit keamanan
014	`014_supplier_settlements.sql`	Settlement supplier
015	`015_shadow_bars.sql`	Ambang shadow-mode
016	`016_guest_preferred_currency.sql`	Mata uang pilihan tamu (IDR/USD)
017	`017_property_geo.sql`	Koordinat properti + presisi + sumber (Bab 15), idempoten

10. State machine booking (32 status)

Sumber: `docs/BOOKING_STATE_MACHINE.md` v1.1, kode `src/booking_states.py` (1.051 baris).

10.1 Tiga puluh dua status per fase

Fase	Status
Enquiry	`INQUIRY`, `QUALIFIED`
Ketersediaan	`AVAILABILITY_PENDING`, `AVAILABILITY_CONFIRMED`, `AVAILABILITY_UNAVAILABLE`
Penawaran	`QUOTE_DRAFTED`, `QUOTE_SENT`, `QUOTE_EXPIRED`
Hold	`HOLD_REQUESTED`, `HOLD_ACTIVE`, `HOLD_EXPIRED`
Pembayaran	`PAYMENT_PENDING`, `PAYMENT_PARTIAL`, `PAYMENT_UNMATCHED`, `PAYMENT_FAILED`, `DEPOSIT_PAID`, `PAID_IN_FULL`
Kepastian & kedatangan	`CONFIRMED`, `BALANCE_DUE`, `BALANCE_OVERDUE`, `PRE_ARRIVAL`, `IN_STAY`
Selesai	`COMPLETED`
Pembatalan	`CANCELLATION_REQUESTED`, `CANCELLATION_REVIEW`, `CANCELLED`, `REFUND_PENDING`, `REFUNDED`
Kasus khusus	`NO_SHOW`, `RELOCATED`, `DISPUTED`
Penutup	`CLOSED`

`INQUIRY` = satu-satunya status awal. `CLOSED` = satu-satunya status terminal; tidak pernah berpindah lagi (diuji untuk 32 target).

10.2 Graf

120 sisi legal dari 1.024 pasangan terurut (32×32): 31 self-transition ditolak (`SELF_TRANSITION`), 32 pasangan dari status terminal ditolak (`TERMINAL_STATE`), sisanya 841 ilegal (`INVALID_TRANSITION`). Empat sisi tambahan berasal dari ADR-0069 opsi (a) — pembatalan langsung dari `CONFIRMED` , `BALANCE_DUE` , `PRE_ARRIVAL` , dan `IN_STAY` , selalu wajib `reason` . Setiap pasangan diklasifikasi tepat sekali (`test_every_pair_is_classified_exactly_once`).

Jalur utama:

```
INQUIRY → QUALIFIED → AVAILABILITY_CONFIRMED → QUOTE_SENT → HOLD_ACTIVE
       → DEPOSIT_PAID → CONFIRMED → PRE_ARRIVAL → IN_STAY → COMPLETED → CLOSED
```

Jalur ini dijalankan utuh oleh `scripts/go_live_smoke.py` pada DB kosong (webhook bertanda tangan → kasus → intake direview → bukti ketersediaan → quote → penawaran diterima → hold → booking → invoice → pembayaran via webhook → dokumen → menginap → settlement supplier + deposit → gate §30 → `CLOSED`), dikunci `tests/test_go_live_smoke.py` .

Jalur pintas (fast path) — melewati status pembukuan, *bukan* fakta; guard tetap berlaku:

Sisi	Alasan
`QUALIFIED → AVAILABILITY_CONFIRMED`	manager sudah memegang kalender owner
`AVAILABILITY_CONFIRMED → QUOTE_SENT`	quote dikirim lewat templat tanpa draf terpisah
`QUOTE_SENT → HOLD_ACTIVE`	hold aktif saat bukti transfer masuk
`HOLD_ACTIVE → DEPOSIT_PAID`	transfer bank Indonesia sering cair di dalam jendela hold
`IN_STAY → CANCELLATION_REQUESTED`	tamu minta pulang lebih awal

10.3 Delapan status yang menempati slot

`CONFIRMED` , `BALANCE_DUE` , `BALANCE_OVERDUE` , `PRE_ARRIVAL` , `IN_STAY` , `CANCELLATION_REQUESTED` , `CANCELLATION_REVIEW` , `DISPUTED` . Tiga terakhir ditambahkan oleh **ADR-0002 Opsi A** (2026-09-21): pembatalan yang masih ditinjau, dan sengketa saat tamu masih fisik di unit, tetap menahan tanggal. Fail-closed: lebih baik unit tertahan selama review daripada double booking. Status lain (`CANCELLED` , `CLOSED` , `NO_SHOW` , `COMPLETED` , `RELOCATED`) melepas slot.

10.4 Aturan khusus yang disengaja

1. `NO_SHOW` **tidak bisa** dari `IN_STAY` (akan melepas slot saat tamu masih di dalam → risiko double booking + okupansi salah). No-show diputuskan sebelum kedatangan: dari `CONFIRMED` , `BALANCE_DUE` , `BALANCE_OVERDUE` , `PRE_ARRIVAL` , `CANCELLATION_REVIEW` .
2. `CLOSED` tidak punya sisi keluar; koreksi pasca tutup buku = kasus baru (`DISPUTED` dibuka *sebelum* penutupan).
3. Tidak ada self-loop.
4. Setiap status non-terminal harus bisa keluar dan mencapai `CLOSED` .

10.5 Guard

Guard	Field wajib	Dipakai pada
`evidence`	`evidence_ref`	semua pergerakan pembayaran, `CONFIRMED` , `AVAILABILITY_CONFIRMED`
`reason`	`reason`	`CANCELLED` , `NO_SHOW` , `DISPUTED` , `CANCELLATION_REQUESTED` , `RELOCATED` , `REFUND_PENDING`
`approval`	`approval_ref`	`RELOCATED` , `REFUND_PENDING` , `REFUNDED` , `CANCELLATION_REVIEW→CANCELLED`

Urutan evaluasi: `evidence` → `reason` → `approval` (bukti dulu: pergerakan tanpa bukti tak boleh “disetujui menjadi sah”). Laporan guard terurut alfabetis. Guard kustom yang menolak melempar `DomainError` dengan kode sendiri. Nama guard tak dikenal → `UNKNOWN_GUARD` .

10.6 Perintah kernel setelah booking

Perintah	Dari → ke	Oleh
`reserve_from_hold`	`HOLD_ACTIVE` → `PAYMENT_PENDING`	reservation (hold tetap memegang slot)
`mark_paid`	`PAYMENT_PENDING` → `DEPOSIT_PAID` / `PAID_IN_FULL`	finance, dengan pembayaran `SUCCEEDED`
`confirm_booking`	`DEPOSIT_PAID` / `PAID_IN_FULL` → `CONFIRMED`	reservation, dengan bukti blok villa A/B sesudah reservasi (ADR-0033; audit 2026-11-13 K2 — `confirm_from_hold` dipensiunkan)
`prepare_arrival`	`CONFIRMED` → `PRE_ARRIVAL`	tim reservasi
`check_in`	`PRE_ARRIVAL` → `IN_STAY`	reservasi/greeting saat tamu tiba
`complete_stay`	`IN_STAY` → `COMPLETED`	tim operasi
`cancel_booking`	hampir semua status hidup → `CANCELLED`	reservation + approval untuk uang (ADR-0002)
`close_booking`	`COMPLETED` → `CLOSED`	sistem, hanya bila gate §30 lulus penuh

Perintah diulang pada status yang sama = idempoten (bukan error); lompatan status = `BOOKING_TRANSITION_REFUSED` (`tests/test_booking_stay_progress.py`).

10.7 Jurnal transisi

Setiap perpindahan = satu baris `booking_state_events` (13 kolom persis DDL: `state_event_id, booking_id, seq, from_state, to_state, command, actor, actor_role, command_id, evidence_ref, approval_ref, reason, occurred_at`) + audit di `audit_events` dalam **transaksi yang sama**. Append-only. `occurred_at` ISO-8601 sadar zona.

Kode error: `UNKNOWN_STATE`, `SELF_TRANSITION`, `INVALID_TRANSITION`, `TERMINAL_STATE`, `MISSING_FIELD`, `INVALID_FIELD`, `MISSING_REASON`, `MISSING_EVIDENCE`, `MISSING_APPROVAL`, `UNKNOWN_GUARD`, `SCHEMA_STATE_ENUM_MISMATCH`, `SCHEMA_ENUM_UNAVAILABLE`, `INVALID_STATE_GRAPH`.

10.8 Pembedaan “Booked” yang paling sering salah (ADR-0034, ADR-0033)

Tim reservasi memakai tiga nama tahap hold. Ketiganya **label**, bukan status baru:

Tahap (bahasa bisnis)	Status booking	Status hold	Syarat
1. **Tentative Holding**	`HOLD_REQUESTED`	`REQUESTED` / `AWAITING_SUPPLIER`	unit ditahan sementara tamu memutuskan; villa **belum** mengonfirmasi
2. **Request Hold**	`HOLD_ACTIVE` → `PAYMENT_PENDING`	`CONFIRMED`	villa **sudah** mengonfirmasi hold; uang tak pernah diterima atas hold yang belum dikonfirmasi
3. **Holding Booking Confirmed / Villa Booked**	`DEPOSIT_PAID` / `PAID_IN_FULL` → `CONFIRMED`	`CONVERTED`	dana terverifikasi masuk akun agency; `CONFIRMED` masih menuntut bukti blok dari villa
Batal / tamu tidak bayar	`CANCELLED`	`RELEASE_REQUESTED` → `RELEASE_CONFIRMED`	Reservation mengirim surat/email release hold ke villa

Tahap 3 bernama “Booking Confirmed”, tetapi status `CONFIRMED` baru tercapai setelah bukti blok villa diterima. Dana masuk saja = `DEPOSIT_PAID` / `PAID_IN_FULL`. Laporan yang menghitung `CONFIRMED` sebagai “uang masuk” *kurang hitung*; laporan yang menghitung `DEPOSIT_PAID` sebagai “booked penuh” *lebih hitung*.

11. Hold, ketersediaan, dan bukti

11.1 Ketersediaan berjenjang (Level bukti A–D)

Level	Sumber	Boleh di-quote?	Boleh di-hold?	Boleh dikonfirmasi?
A	API/booking engine properti	Ya	Ya	Ya (dalam freshness window)
B	Tulisan resmi manajer properti	Ya	Ya	Ya (dalam freshness window)
C	iCal/OTA publik	Ya (label “indicative”)	Ya, sebagai hold sementara	**Tidak**
D	Memori lama / tanpa sumber	Tidak	Tidak	Tidak

Freshness default (per policy, ada batas guardrail): A = 900 detik (maks 3.600), B = 86.400 detik (maks 172.800), C = 172.800 detik (maks 604.800). `confirm_requires_level` default `A_or_B`, tidak boleh `C` / `D`. Bukti hilang/basi/timeout → **`UNKNOWN`** → tidak boleh dijual sebagai confirmed. Kemampuan `can_quote` / `can_hold` / `can_confirm` dihitung dari level + umur bukti (`availability_evidence`, bukan ingatan orang).

11.2 Aturan hold

Aturan	Nilai default (policy)	Guardrail
Lama hold `hold_ttl_minutes`	120 menit	15–1.440
Perpanjangan `max_hold_extensions`	1	0–3; harus eksplisit + audit
Quote valid `quote_valid_hours`	24 jam	1–168

`HOLD_REQUESTED ≠ HOLD_CONFIRMED` (`hold_states.py`). Hold kedaluwarsa menjadi antrean kerja (ditagih scheduler tiap 5 menit). Hold yang menutup *expiry* butuh bukti level A. Item terbuka tercatat di ADR-0020: bukti buatan sendiri di `request_hold`, baris extension menggantung, `verify_expired_hold` belum punya tombol **[potret 2026-10-03]**.

11.3 Bukti file (evidence)

File yang datang dari luar masuk jalur karantina (`src/evidence.py`): objek bukti, peristiwa bukti, izin akses bertenggat. Dokumen/pesan dari tamu atau owner diperlakukan sebagai **data tak tepercaya**, bukan instruksi (red line #7). Screenshot transfer **tidak pernah** menjadi bukti `CLEARED`.

12. Policy sebagai data dan kalkulasi quote

12.1 Prinsip

Semua angka bisnis hidup di satu objek berversi: `PolicyVersion` per properti (opsional per unit). Policy **tidak pernah diedit**; perubahan = versi baru dengan `effective_from` baru. Quote dan booking menyimpan `policy_version_id` **dan** `policy_fingerprint`. Booking aktif tetap memakai snapshot saat dibuat. Rentang efektif antar versi tidak boleh overlap (kalau boleh, satu tanggal punya dua harga). Katalog policy: **25 dari 25 key terbit**; key tanpa revisi **ditolak**, bukan diberi nilai karangan.

12.2 Isi policy (POLICY_MATRIX v1.0)

Kelompok	Field → default → guardrail
Identitas & masa berlaku	`policy_version_id`, `property_id`, `unit_scope` (`property`/unit_id), `version` (naik monoton), `effective_from`/`effective_to`, `currency` (default IDR; hanya mata uang dengan minor unit), `source_doc_ref` (wajib), `approved_by` (wajib untuk versi pertama)
Deposit & jadwal bayar	`deposit_pct` 50 (0–100; 100 = wajib lunas) · `full_payment_window_days` 45 · `balance_due_days_before_arrival` 45 (≥1) · `deposit_confirms_booking` false · `security_deposit_minor` 0 (refundable, bukan pendapatan) · `security_deposit_refund_days` 7 · `quote_valid_hours` 24 · `hold_ttl_minutes` 120 · `max_hold_extensions` 1 · `payment_terms_text` (wajib)
Pembatalan & no-show	`cancellation_tiers` = daftar `(days_before_arrival_min, penalty_pct)` menurun; tier berlaku = tier pertama yang `days_before_arrival ≥ min`. Contoh: `[(60,0),(30,50),(0,100)]` high season; `[(30,0),(7,50),(0,100)]` standar; `[(0,100)]` non-refundable. `no_show_penalty_pct` 100 · `force_majeure_clause` (wajib, menyebut ≥1 skenario lokal + mekanisme refund/kredit) · `blackout_dates` (ditolak `BLACKOUT_DATE`)
Harga & biaya	`base_capacity` 2 · `max_guests` 4 (lebih → `OVER_CAPACITY`) · `extra_guest_fee_minor_per_night` 0 · `cleaning_fee_minor` 0 · `min_stay_nights` 2 · `child_policy`/`pet_policy`/`event_policy` (wajib) · `max_discount_pct` 10 (0–50)
Pajak & fee	`tax_pbjt_pct` per kabupaten/kota, **≤ 10** · `tax_applies_to` (`subtotal` / `subtotal_plus_service`) · `service_fee_pct` 10 (0–25) · `tax_included_in_rate` false (true → PBJT dihitung mundur)
Inventory	`availability_freshness_A/B/C_seconds` · `confirm_requires_level` · `channel_quota`
Check-in/out	`check_in_time` 14:00 · `check_out_time` 12:00 · `property_timezone` (`Asia/Makassar` Bali, `Asia/Jakarta` Yogyakarta) · `check_in_document_required` true

> Angka “default” di tabel adalah nilai awal di dokumen kerja, **bukan** keputusan bisnis seragam untuk semua villa. Nilai nyata diisi per properti oleh tenant (GO_LIVE D5, ADR-0037). **Jangan hard-code tarif PBJT.**

Perubahan yang **wajib** approval manusia + audit: `tax_pbjt_pct`, `service_fee_pct`, `deposit_pct`, `cancellation_tiers`, `security_deposit_minor`, `currency`, `full_payment_window_days`.

12.3 Kalkulator quote

`src/quote_calculator.py` (711 baris) menghitung deterministik: malam × tarif (rate card bermusim: `rate_cards`/`rate_versions`/`rate_seasons`; ADR-0031 “a rate is a days price”), biaya tamu tambahan, kebersihan, service fee, PBJT, diskon. Hasilnya disimpan sebagai **snapshot** (`quotation_snapshots`) dengan versi (`quotation_versions`) dan penerimaan (`quotation_acceptances`) — ADR-0025. LLM **tidak** menghitung uang.

Mesin diskon (`discounts.py`, ADR-0026/0029/0030): diskon dibatasi `max_discount_pct`, nilai batas dipublikasikan, lantai absolut membawa mata uang (ADR-0030), diskon di luar batas naik ke manusia (Operations/Reservation Manager). Penjelasan harga untuk tamu adalah **jawaban**, penawaran adalah **satu tindakan** (`quotation.send`, ADR-0046).

---

13. Uang: invoice, pembayaran, rekonsiliasi, kurs, settlement

Sumber: Panduan Alur Kerja §6, Operations Runbook §6–§7 dan §13, `docs/POLICY_MATRIX.md`, ADR-0012/0013/0033/0036/0055/0056/0060.

13.1 Alur uang satu arah

```
 Penawaran (quote, snapshot harga)
       │  tamu setuju (quotation_acceptances)
       ▼
Invoice (invoices + invoice_lines: malam, pajak, layanan, diskon)
       │  tamu bayar lewat kanal resmi (transfer bank / payment gateway)
       ▼
Bukti masuk (payments + payment_events) ──► Rekonsiliasi: nominal + tanggal + referensi + nama pengirim
       │ cocok                                          │ tidak cocok
       ▼                                                ▼
DEPOSIT_PAID / PAID_IN_FULL                    PAYMENT_UNMATCHED → reconciliation_cases (SLA 48 jam)
       │
       ▼
Kewajiban ke pemilik villa (supplier_settlements)
       │  uang keluar → approval dua penyetuju berbeda
       ▼
Pembayaran ke pemilik → bukti transfer dicatat → selesai
```

Sistem **tidak memindahkan uang**. Ia mencatat, mencocokkan, dan meminta persetujuan; eksekusi transfer tetap di rekening bank atau penyedia pembayaran.

13.2 Empat penjaga jalur uang

1. **Tanpa pecahan mengambang.** Semua uang bilangan bulat satuan terkecil.
2. **Tanpa tagihan tanpa asal.** Setiap baris invoice harus ditelusuri ke rate card/policy bertanggal atau ke biaya yang disetujui.
3. **Uang keluar = dua tanda tangan.** Refund, payout ke pemilik villa, dan perubahan rekening bank wajib **dua penyetuju berbeda**; **pemohon tidak boleh menyetujui permintaannya sendiri** (modul `approvals`; status diturunkan dari log keputusan, mengubah kolom status langsung tidak mengubah kenyataan). ADR-0036: uang keluar lewat tangan manusia dan GM menyetujui lebih dulu.
4. **Kurs punya masa berlaku.** Konversi memakai kurs harian yang disetujui. Kurs lebih tua dari **48 jam** (`commercial.fx.max_age_hours`, batas owner) ditolak dengan `FX_RATE_STALE` — bukan dipakai diam-diam.

13.3 Kurs harian

Perintah: `VILLA_DB=data/villa.db python3 scripts/refresh_fx_rate.py --approved-by <identitas>` — sekali sehari (ADR-0031). Lantai margin dikonversi dengan kurs ini untuk booking di luar mata uang lantai (Bali USD, Yogyakarta IDR).

Hasil	Arti	Tindakan
`FETCHED`	angka + waktu kutipan dari provider	normal
`UNCHANGED`	pasar belum bergerak; tidak ada revisi baru	normal
`REFUSED`	payload dicurigai (lonjakan > `--max-move-pct`, rate bukan desimal eksak, base salah, kutipan bertanggal masa depan)	**tidak ada yang tertulis**; periksa provider, jangan naikkan batas

Alat menolak menerbitkan bila kutipan provider lebih tua dari `--max-feed-age-hours` (feed mati bukan kurs). **Jangan** memberi `--effective-from` bertanggal lokal WIB: revisi itu lahir “besok” bagi platform (UTC) dan store menolak mundur untuk mengoreksi.

13.4 Rekonsiliasi (SLA 48 jam)

Jenis kasus: `UNMATCHED_PAYMENT`, `AMOUNT_MISMATCH`, `DUPLICATE_EVENT`, `UNVERIFIED_WEBHOOK`.

1. **Jangan** menandai invoice lunas dari screenshot — cari bukti di penyedia pembayaran/mutasi bank (red line #4).
2. Cocokkan nominal, tanggal, referensi, nama pengirim.
3. Selesaikan kasus dengan catatan (`resolution_note` wajib oleh skema; status `RESOLVED` + baris ledger yang menyeimbangkan).
4. Bukan pembayaran sah → kembalikan sesuai kebijakan (approval bila ada uang keluar), insiden fraud bila ada indikasi.

Webhook retry tidak boleh menggandakan efek ledger: `idempotency_keys` + `DUPLICATE_EVENT`; target Charter: payment reconciliation ≥ 99%.

13.5 Invoice dan penagihan

Heartbeat membuka tugas `PAYMENT_CHASE` untuk invoice lewat jatuh tempo (naik prioritas setelah 7 hari). Tugas itu **tidak** menghubungi tamu; ia menugaskan manusia menyiapkan draft pesan. Penagihan ke tamu tetap butuh persetujuan.

13.6 Mata uang

IDR dan USD (ADR-0060; kolom `guests.preferred_currency`, migrasi 016). Bali USD, Yogyakarta IDR sebagai mata uang lantai margin (ADR-0030: lantai absolut membawa mata uang). Stablecoin USDC/USDT punya kontrol sendiri (ADR-0013) dan orkestrasi payment rails (ADR-0012). Aturan Rupiah dan PJP wajib ditinjau counsel (Bab 21).

13.7 Uang masuk ≠ villa dikonfirmasi (ADR-0033)

`DEPOSIT_PAID` / `PAID_IN_FULL` = dana terverifikasi masuk akun agency. `CONFIRMED` = villa memblokir tanggal (bukti blok diterima). Laporan keuangan memakai status uang; laporan operasional memakai status blok villa. Mencampur keduanya menghasilkan angka salah.

13.8 Fakta tambahan pembayaran/pemulihan

- **Deposit keamanan** (`security_deposit_minor`) refundable, bukan pendapatan; `deposit_resolutions` (migrasi 013, ADR-0055) mencatat penyelesaiannya.
- **Settlement supplier** (`supplier_settlements`, migrasi 014, ADR-0056) mencatat kewajiban ke villa/owner.
- **Cadangan (D10, disetujui owner 2026-10-02):** RPO 24 jam, RTO 4 jam, salinan di luar server utama, uji pemulihan tiap 3 bulan oleh Mr. TS.

BAGIAN IV — PERMUKAAN PRODUK

14. Situs publik (marketing)

Modul `src/marketing_site.py` (≈1.200 baris) adalah toko depan untuk calon tamu. Batas produk ditetapkan di `docs/PRODUCT_SURFACE_SEPARATION_2026-10-05.md`: situs berbagi *kernel* (tulang punggung kasus, master tamu CRM, kueri inventaris baca-saja) dengan dashboard, tetapi **tidak pernah** menampilkan audit chain, approval, keuangan, halaman staf, atau back office kanal.

14.1 Halaman dan rute

Rute	Metode	Fungsi
`/`	GET	Beranda: hero, villa unggulan (maks 3), peta area
`/villas`	GET	Katalog villa yang berstatus `SELLABLE` + peta area
`/villas/<id>`	GET	Detail villa: cerita, sorotan, unit, blok "Where you'll be" (peta + landmark), galeri suasana, SLA
`/destinations/bali`, `/destinations/yogyakarta`	GET	Halaman destinasi + peta area
`/owners`	GET	Halaman untuk pemilik villa
`/inquiry`	GET, POST	Formulir pertanyaan; POST membuka kasus di kernel (satu-satunya jalur tulis)
`/favicon.ico`	GET	204
selain itu	—	404; POST ke selain `/inquiry` → 405

Semua id di URL divalidasi `require_ref`; id rusak = 404, bukan galat. Hanya villa berstatus `SELLABLE` yang tampil (`SELLABLE_STATUS`).

14.2 Keputusan yang tercatat di kepala modul

1. **Bahasa:** en-US untuk salinan publik (ADR-0011); lokal Indonesia = keputusan terpisah di masa depan.
2. **Tidak ada harga di situs.** Mata uang default tamu baru (`preferred_currency`, IDR atau USD) disimpulkan dari negara tampak pengunjung (header `CF-IPCountry`, ADR-0060) hanya untuk tampilan staf; tidak pernah menentukan harga. Setiap penawaran dikirim manusia.
3. **PII tamu:** email di tabel `guests` (lewat `CrmService`); kasus hanya membawa `guest_id` buram. Isi pesan disimpan di kelas konten **P2**: salinan tersimpan diredaksi, teks mentah hanya bertahan sebagai digest sha256.
4. **SLA:** kanal `website` → kebijakan `web_v1`; waktu respons yang dijanjikan di situs dibaca dari `cases.SLA_POLICIES` saat render, tidak ditulis ulang.
5. **Satu berkas respons:** CSS dan SVG inline; foto villa adalah JPEG base64 dari `assets/photos/` yang dibaca saat startup. Tidak ada rute baru, tidak ada permintaan keluar dari halaman. **Foto adalah stok CC BY-SA/CC0 dari Wikimedia Commons, bukan foto properti sungguhan** (kredit: `docs/PHOTO_CREDITS_2026-10-06.md`); halaman menyatakannya. Villa tanpa kecocokan kata kunci tampil kartu "Photo coming soon".
6. **Salinan wilayah, bukan properti** (ADR-0065): `src/villa_showcase.py` menulis prosa tentang *wilayah* dan menyorot hanya angka yang disimpan kernel (jumlah unit, kamar tidur, kapasitas). Detail yang belum terverifikasi dijawab dengan `DISCLOSURE` ("dikonfirmasi tim kami"), tidak dikarang. Mengganti dengan foto/salinan asli = melalui `evidence_objects` (butuh pindai bersih + klasifikasi), bukan mengubah modul itu.

14.3 Perlindungan formulir (semua fail-closed)

Lapisan	Aturan (nilai dari kode)
Honeypot	kolom `company` terisi → `SPAM_REJECTED`
Same-origin	header `Origin` ada dan `netloc` ≠ `Host` → `FORM_INVALID`
Rate limit	`SlidingWindowRateLimiter`: **5 kiriman / 600 detik per alamat**; maks 4.096 klien terlacak (tanpa batas, pemutar alamat IPv6 /64 menumbuhkan memori selamanya) → HTTP 429 + `Retry-After`
Ukuran	form maks 32 KiB; nama ≤ 100; email ≤ 320; pesan 10–5.000 karakter; ≤ 32 field; nama field ganda ditolak
Token formulir	`form_token = issued_at | nonce | HMAC-SHA256` (58 heks), ditandatangani dengan `VILLA_FORM_TOKEN_KEY` (≥ 32 byte; tanpa itu kunci acak per proses). Ditolak bila MAC salah, umur < 3 detik (bot) atau > 2 jam (basi) — audit 2026-11-13 S1. Tetap menjadi **kunci idempotensi** kasus. Mode `--dump` statis: token di HTML basi setelah 2 jam
Retry	token sama + isi sama → hasil sebelumnya dikembalikan; token sama + isi/email/villa berbeda → ditolak ("form sudah dipakai")
Email	pola longgar `x@y.z`; tamu ada → dipakai ulang, tidak ada → `register_guest`
Rujukan villa	`property_ref` divalidasi `require_ref`; rusak → "unknown villa reference"
Alamat klien	tanpa `--trusted-proxy`: alamat soket. Dengan proxy tepercaya: **elemen terakhir** `X-Forwarded-For` (yang ditulis proxy sendiri; ADR-0067), dinormalkan lewat `ipaddress` (bentuk `::ffff:a.b.c.d` = a.b.c.d). `--trusted-proxy` **ditolak** bersama `--allow-remote`
Soket menggantung	timeout koneksi 20 detik (server satu-utas; satu soket diam tidak boleh melumpuhkan semua pengunjung)

Header respons: `Content-Security-Policy: default-src 'self'; style-src 'unsafe-inline'; img-src 'self' data:; form-action 'self'; frame-ancestors 'none'; base-uri 'self'`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`, `X-Frame-Options: DENY`, `Cache-Control` (halaman formulir `no-store`). Tidak ada skrip sama sekali.

14.4 Fail-safe render (ADR/komit `ade3710`, 2026-11-12)

`do_GET` / `do_POST` membungkus pengiriman: pengecualian apa pun → jejak tumpukan ke jurnal (tidak ke pengunjung) dan **halaman 500** biasa, bukan soket yang ditutup. Sebelumnya modul yang kedaluwarsa melempar `TemplateError` untuk `{{area_map}}` dan klien melihat "empty reply" sementara health check melihat proses hidup. Kasus `BrokenPipeError` / `ConnectionResetError` tetap dilempar (klien pergi; bukan galat render). Uji: `TestRenderFailSafe::test_render_error_returns_a_500_page`.

14.5 Menjalankan

```
python3 src/marketing_site.py --db data/villa.db --port 8090 [--trusted-proxy] [--allow-remote]
python3 src/marketing_site.py --db /tmp/demo/villa.db --dump /tmp/demo/site   # situs statis
```

Unit: `deploy/systemd-user/villa-marketing.service` — loopback `127.0.0.1:8090`, `--trusted-proxy`, hardening (`NoNewPrivileges`, `PrivateTmp`, `ProtectSystem=strict`, `ProtectHome=read-only`, `ReadWritePaths` hanya `data/`, `MemoryDenyWriteExecute`, `RestrictAddressFamilies`, `UMask=0077`). `PrivateDevices` / `ProtectKernelModules` / `CapabilityBoundingSet` **sengaja tidak ada** karena unit *user* mati dengan `218/CAPABILITIES`; itu milik unit sistem (DEPLOYMENT §4.2). TLS, nama publik, dan identitas rate-limit = tugas reverse proxy.

15. Maps & Geo (peta area villa)

15.1 Masalah yang diselesaikan

Peta membantu tamu merencanakan perjalanan, tetapi **koordinat pintu villa adalah data paling mudah disalahgunakan** milik agency: orang bisa mendatangi rumah pribadi, dan pesaing bisa menebak identitas pemilik dari sebuah pin. Maka modul `src/geo.py` memisahkan tiga hal:

Presisi (`geo_precision`)	Arti	Boleh tampil di publik?
`VERIFIED`	koordinat yang dikunjungi manusia atau diberikan pemilik secara tertulis	ya, **dibulatkan**
`AREA_APPROX`	desa/pantai tempat villa berada	ya, dibulatkan; ditandai "area only"
`UNKNOWN` (default)	tidak ada klaim	**tidak**; halaman berkata dengan kata-kata, bukan pin

15.2 Aturan privasi (ditegakkan kode, bukan komentar)

1. Semua yang ke publik melewati `public_point`, pembulatan **2 desimal** (`PUBLIC_ROUNDING_DP = 2`) ≈ 1,11 km lintang (≈ 0,55 km per sumbu dari pusat sel). Situs diberi pasangan yang sudah dibulatkan *walaupun DB menyimpan yang tepat*, sehingga perubahan templat tak bisa membocorkan nilai presisi. Uji: `test_public_point_rounds_and_the_loss_is_bounded`, `test_locator_map_never_prints_the_exact_coordinate`, `test_two_exact_points_in_one_rounding_cell_draw_identically` (dua titik tepat berbeda dalam satu sel = piksel identik).
2. `resolve_point` mengembalikan `None` (= tidak ada klaim) bila lintang/bujur kosong, hanya setengah terisi (tidak "diperbaiki"), atau presisi `UNKNOWN`.
3. `validate_coordinate` menolak `NaN`/tak hingga/boolean/teks bukan angka dan di luar [-90,90]/[-180,180]. `NaN` lolos semua pembanding sehingga cek rentang naif akan menaruh pin di `(nan, nan)`.
4. Baris dengan pasangan rusak (basis data disunting tangan, impor setengah jalan) → `_villa_point` mengembalikan `None`; satu baris buruk tidak menjatuhkan seluruh katalog.
5. DB yang belum bermigrasi 017 tetap melayani katalog tanpa pin (`has_geo` mendeteksi kolom; `_geo_select` memberi `NULL, 'UNKNOWN'`) — bukan 500.

15.3 Peta tanpa aset eksternal

Peta adalah SVG yang digambar `geo.py` sendiri: tanpa tile server, tanpa JavaScript, tanpa permintaan pihak ketiga dari browser tamu (CSP `default-src 'self'`). Alasannya: minat tamu pada sebuah villa bukan sesuatu yang diserahkan ke vendor peta, dan halaman yang render offline = satu hal yang tak bisa rusak Sabtu malam pukul 21:00.

Komponen	Fungsi
`BBox`	jendela lintang/bujur berpadding 12%, lebar minimum 0,05° agar satu titik tidak memenuhi bingkai dan dua villa sedesa tidak jatuh ke satu piksel; proyeksi ekuirektangular dengan koreksi cos(lintang) pada bujur
`area_map_svg`	peta area 880×380: graticule 3 garis, label, pin (lingkaran emas, `<title>` aksesibel), skala bar dengan panjang kilometer bulat (1,2,5,10,… 500)
`locator_map_svg`	peta zoom 520×280: titik villa publik + 3 landmark terdekat, keterangan "pin menandai area, bukan gerbang; jarak garis lurus"
`nearest_landmarks`	landmark provinsi terurut jarak; provinsi tak dikenal → daftar kosong, bukan tebakan
`haversine_km`	jarak lingkaran besar, radius bumi 6.371,0088 km (IUGG); sengaja "garis lurus", bukan waktu tempuh yang tak pernah diukur
`_svg_text`	escape `&` `<` `>` `"` `'` untuk setiap label/aria (ada uji XSS pada label dan aria)

Landmark referensi (dibaca dari OpenStreetMap Nominatim, 2026-11-12; data referensi, bukan lokasi villa): Bali — Ngurah Rai Airport, Canggu Beach, Seminyak Beach, Ubud Palace, Tanah Lot, Uluwatu Temple. DI Yogyakarta — Adisutjipto Airport, YIA, Malioboro, Prambanan, Borobudur, Kotagede. Detail memuat 4 terdekat secara bawaan; peta zoom menandai 3.

15.4 Pemasangan di halaman

`{{area_map}}` ada di `home.html`, `villas.html`, `destination.html`; `{{villa_locator}}` di `villa_detail.html`. Bila **tak satu pun** villa punya titik publik, `_area_map_html` mengembalikan kosong (peta kosong menyiratkan "kami tak punya villa"); detail villa menampilkan "Where you'll be … kami bagikan alamat tepat dan pin setelah booking dikonfirmasi".

15.5 Skema (migrasi 017 + `001_initial.sql`)

Empat kolom di `properties`: `latitude REAL`, `longitude REAL`, `geo_precision TEXT NOT NULL DEFAULT 'UNKNOWN' CHECK IN ('UNKNOWN','AREA_APPROX','VERIFIED')`, `geo_source TEXT` (2–200 karakter; bukti audit "dari mana pin ini"). Dipisah (bukan satu JSON) karena koordinat = bahan peta, presisi = penentu boleh-tampil, sumber = bahan pertanggungjawaban. `017_property_geo.sql` idempoten untuk DB lama; DB baru sudah punya kolom dari `001_initial.sql` (twin PG diperbarui). Semua properti lama otomatis `UNKNOWN` (aman secara konstruksi).

15.6 Pengujian

`tests/test_geo.py` (215 baris, 19 fungsi `test_*`; konstanta dihitung dengan aritmetika independen 111,195 km/derajat, bukan menyalin implementasi) + `TestPropertyMaps` dan `TestRenderFailSafe` di `tests/test_marketing_site.py`. Skenario: `UNKNOWN` → tanpa peta dan tanpa placeholder; `VERIFIED` → peta area + locator bernama; `AREA_APPROX` → peta bertanda perkiraan.

15.7 Keadaan hidup dan keputusan yang menunggu

Migrasi 017 diterapkan ke `data/villa.db` pada 2026-11-12 (setelah uji pada salinan + backup). DB hidup: 3 properti, **semuanya `UNKNOWN`, lintang/bujur NULL** → situs kini menampilkan peta area kosong-aman (tanpa pin). *Keputusan Owner:* mengisi koordinat + presisi + sumber untuk 3 villa pilot dari sumber terverifikasi (Bab 26).

> **Dua cacat yang ditemukan saat menyusun bab ini — keduanya sudah ditutup 2026-11-13, dirinci di Lampiran F:** (1) komentar di `001_initial.sql`, `001_initial.pg.sql`, dan `017_property_geo.sql` memberi label peta "ADR-0061", padahal `docs/adr/0061-agent-telemetry-tool-effects.md` adalah ADR tentang efek tool agen telemetri (dan memang itu yang dirujuk `control_tower.py`, `operations_agent.py`, `revenue_bi_agent.py`) — **peta geo kini punya ADR sendiri, ADR-0068**; (2) komentar 017 menyatakan aturan "VERIFIED mengharuskan koordinat" ditegakkan di `villa_import.validate_geo_fields`, tetapi **fungsi itu tidak ada**: `src/villa_import.py` ada namun tidak menyentuh kolom geo sama sekali, jadi `scripts/import_villas.py` belum bisa mengisi koordinat/presisi/sumber. Pengaman yang nyata hanya `resolve_point` (VERIFIED tanpa koordinat → tidak tampil) dan CHECK rentang lintang/bujur serta daftar presisi di skema. **Koreksi 2026-11-13:** aturan itu sekarang ada sebagai `geo.validate_geo_fields` dan dipanggil oleh jalur impor (`villa_import._geo`) serta kernel (`upsert_property`), dengan tes di `tests/test_geo.py` dan `tests/test_villa_import.py`. Mengisi 3 villa pilot tetap menunggu sumber terverifikasi (Bab 25 butir 10, Bab 26.1 butir 1) — yang sudah tersedia hanyalah jalannya, bukan datanya.

16. Dashboard internal

Dashboard internal (`src/dashboard.py`, 3.292 baris) melayani staf di `127.0.0.1:8085`.

16.1 Halaman dan matriks peran (dibaca dari `PAGE_ROLES`, 2026-11-12)

Dashboard (`src/dashboard.py`, 3.292 baris) punya enam peran (`reservation`, `finance`, `operations`, `owner`, `auditor`, `gm`) dan `PAGE_ROLES` berisi 14 entri: 12 halaman navigasi + `case_detail` + `error`. Server menolak permintaan di luar peran (bukan sekadar menyembunyikan tautan). `WRITE_ROLES` = reservation, operations, finance, owner, gm (auditor tidak pernah menulis). `PII_ROLES` = operations, finance.

Halaman	reservation	finance	operations	owner	auditor	gm
command_center	✓	✓	✓	✓	✓	✓
cases	✓	–	✓	✓	✓	✓
case_detail	✓	–	✓	✓	✓	✓
inventory	✓	–	✓	✓	–	–
finance	–	✓	–	✓	–	✓
operations	✓	–	✓	✓	–	–
approvals	✓	✓	✓	✓	✓	✓
properties	✓	✓	✓	✓	✓	✓
marketing	✓	–	✓	✓	✓	–
channels	✓	–	✓	✓	–	–
shadow_eval	–	–	✓	✓	✓	–
outbox	–	–	✓	✓	✓	–
audit	–	–	–	✓	✓	✓
error	✓	✓	✓	✓	✓	✓

> Catatan akurasi: Panduan Alur Kerja 2026-10-29 §8 menulis `properties` tanpa `finance`, `marketing` tanpa `auditor`, dan `channels` dengan `auditor` — ketiganya **berbeda dari kode hari ini**. Tabel di atas dari kode (benar); tabel di Panduan perlu dikoreksi. Probe matriks akses lewat HTTP sungguhan (dengan kontrol negatif: tanpa token 401, token palsu 401, header peran palsu ke `/finance` 403): `scripts/access_matrix_probe.py`.

16.2 Dua jenis kredensial (ADR-0005, `docs/security/SESSION_AUTH.md`)

	Token mesin (statis)	**Sesi operator**
Dibuat oleh	berkas token (`--token-file`) saat menjalankan dashboard; atau otomatis acak saat start	`scripts/session_token.py login`
Menyebut siapa	tidak — hanya peran	ya — identitas + peran
Kedaluwarsa	tidak (dirotasi manual tiap 90 hari)	idle 30 menit, absolut 12 jam
Dicabut per orang	tidak	ya, seketika
Jejak audit	tidak	`auth_events`: `LOGIN`, `ACCESS_DENIED`, `SESSION_REFUSED`
Dipakai untuk	cron, skrip, integrasi	manusia

Header diterima: `Authorization: Bearer [REDACTED]` atau `X-Dashboard-Token: [REDACTED]`.

Pembaruan 2026-11-12 (bukan di SESSION_AUTH.md lama): token mesin **tidak lagi** diberikan lewat argumen `--token` (terbaca pengguna lokal lain di `/proc/<pid>/cmdline`). Pakai `--token-file <path>` (berkas mode 0600, direktori 0700, tidak kosong). `--token` bersama `--token-file` ditolak; berkas kosong/tak terbaca ditolak tanpa fallback token acak. Unit lokal: `~/.config/villa/dashboard.token`; panduan produksi: `/etc/villa/dashboard.token`. Gerbang `scripts/secret_scan.sh` kini juga menangkap `--token|--password|--secret|--api-key <16+ karakter>` dan `Bearer <20+>` (commit `bc4d2b9`, `5647b23`).

Alur sesi operator: `enroll` (daftar TOTP; secret **tidak** disimpan CLI, hanya `secret_ref`; secret dipasang sebagai variabel lingkungan `VILLA_TOTP_SECRET_<REF>` di `EnvironmentFile`, bukan git) → `confirm` (aktifkan faktor) → `login` (token tampil sekali; database menyimpan hash SHA-256) → pakai → `revoke`. Perintah lain: `list`, `rotate`, `revoke --session-id`, `revoke --identity ... --reason`. Peran yang butuh kode TOTP: **owner, finance_manager, gm**; peran lain tidak (keputusan ADR-0005 §1). Kode TOTP sekali pakai (`MFA_CODE_REPLAYED`, `last_used_step`).

Kosakata login di `session_token.py` mengikuti `src/roles.py` (mis. `finance_manager`, `reservation_agent`, `reservation_manager`), sedangkan kunci peran dashboard (`reservation`, `finance`, …) adalah pemetaan halaman; keduanya bukan dua sistem peran terpisah tetapi dua lapisan nama.

Batas jujur (SESSION_AUTH §5): tidak ada faktor kata sandi (hanya identitas + TOTP); siapa pun yang bisa menjalankan `session_token.py` sudah bisa membaca DB — yang ditambahkan sesi adalah akuntabilitas, kedaluwarsa, pencabutan; header `X-Role` diabaikan (diuji 403); dashboard tetap hanya loopback/VPN.

Kode kegagalan umum: `401` (token salah/idle), `MFA_REQUIRED`, `MFA_FACTOR_INACTIVE`, `MFA_CODE_REPLAYED`, `UNKNOWN_FACTOR`, `SESSION_NOT_FOUND`.

BAGIAN V — ALUR KERJA

17. Perjalanan satu booking dari A sampai Z

Contoh dari Panduan Alur Kerja: Ibu Sari mengirim pesan untuk villa 3 kamar di Seminyak, 20–24 November, 6 tamu. Setiap langkah: siapa bergerak · apa dicatat · apa bisa gagal.

#	Langkah (status)	Siapa	Dicatat	Bisa gagal → perilaku
1	Pertanyaan masuk (`INQUIRY`)	tamu (situs/kanal) atau staf	kasus baru: nomor, sumber, isi asli, waktu	pesan ganda dari penyedia → kunci idempotensi, tidak membuat kasus baru
2	Disaring (`QUALIFIED`)	staf reservasi + usulan AI	tanggal, jumlah tamu, area, anggaran, kebutuhan (bayi/kolam/aksesibilitas)	tanggal belum jelas → tetap `INQUIRY` , sistem tidak menebak
3	Cek ketersediaan (`AVAILABILITY_PENDING` → `AVAILABILITY_CONFIRMED` / `AVAILABILITY_UNAVAILABLE`)	sistem	`availability_checks` + `availability_evidence` (waktu, sumber, masa berlaku)	bukti hilang/tua/timeout → `UNKNOWN` , status menunggu; cek kedaluwarsa tak boleh dipakai konfirmasi
4	Penawaran (`QUOTE_DRAFTED` → `QUOTE_SENT`)	staf menyusun, sistem menghitung	`quotes` + `quotation_snapshots` (harga potret dari rate card + policy)	`QUOTE_EXPIRED` → penawaran baru
5	Tahan tanggal (`HOLD_REQUESTED` → `HOLD_ACTIVE`)	reservasi + villa	`holds`	villa belum konfirmasi → uang tidak boleh masuk
6	Uang masuk (`PAYMENT_PENDING` → `DEPOSIT_PAID` / `PAID_IN_FULL`)	tamu bayar; sistem terima bukti	`payments` , `payment_events` , `ledger_entries` , `invoices` , `invoice_lines`	tanpa invoice cocok → `PAYMENT_UNMATCHED` (antrean, bukan error)
7	Konfirmasi (`CONFIRMED`)	staf reservasi, setelah dana terverifikasi **dan** bukti blok villa	`booking_state_events` + alasan + bukti	"uang masuk" ≠ "villa dikonfirmasi"
8	Pra-kedatangan (`PRE_ARRIVAL`)	tim operasi	`ops_tasks` : kebersihan, check-in, transport, permintaan khusus, bertenggat	tugas lewat tenggat → SLA terlampaui, naik ke antrean perhatian
9	Menginap (`IN_STAY`)	tim operasi	insiden, permintaan tambahan, perubahan tanggal, bukti selesai	keluhan **tidak** mengubah status booking otomatis; jadi insiden terpisah
10	Selesai (`COMPLETED` → `CLOSED`)	operasi menutup layanan; keuangan menutup tagihan; sistem menutup kasus	ringkasan, bukti, status akhir	`CLOSED` terminal; koreksi = kasus baru yang merujuk kasus lama

Pembatalan: `CANCELLATION_REQUESTED → CANCELLATION_REVIEW → CANCELLED → REFUND_PENDING → REFUNDED` . Selama masih ditinjau tanggal **tetap tertahan** (ADR-0002 Opsi A).

Tiga tahap hold dan analogi bioskop: lihat §10.8. Tentative Holding = "tolong tahan dulu, saya tanya teman", kasir belum menekan tombol. Request Hold = tombol ditekan, kursi terkunci beberapa jam, tiket belum dibayar. Holding Booking Confirmed = sudah bayar, tiket tercetak, pintu bioskop mencatat kursi itu milik Anda.

17.1 Satu hari di agensi (contoh)

Jam	Kejadian
07:50	Staf operasi membuka Command Center: 3 approval menunggu, 1 invoice lewat jatuh tempo, 2 hold kedaluwarsa siang ini
08:10	Kasus Bu Sari masuk dari situs; intake mengusulkan tanggal dan jumlah tamu; staf reservasi menyetujui usulan (bukan AI yang menetapkan)
08:25	Sistem cek ketersediaan; bukti villa berumur 3 jam → masih berlaku → `AVAILABILITY_CONFIRMED`
08:40	Penawaran dihitung dari rate card November, dikirim, tersimpan snapshot
11:05–11:20	Tamu setuju; hold diminta; villa mengonfirmasi tahan → `HOLD_ACTIVE`
13:30	Transfer DP masuk; keuangan mencocokkan nominal + referensi → `DEPOSIT_PAID`
14:00	Bukti blok villa diterima → `CONFIRMED` ; tanggal terkunci
Sore	3 tugas pra-kedatangan dibuat (kebersihan, check-in, transport), bertenggat
Malam	Pemilik villa ajukan payout; sistem menuntut dua persetujuan; pemohon tak bisa menyetujui sendiri

Semua langkah dapat ditelusuri ulang dari satu nomor kasus.

18. Katalog skenario

18.1 Skenario gagal / pinggiran (perilaku sistem · tindakan manusia)

Situasi	Perilaku sistem	Tindakan manusia
Data ketersediaan hilang/basi	`UNKNOWN`, tidak bisa konfirmasi	cek ulang ke villa, unggah bukti baru
Pembayaran tidak cocok	`PAYMENT_UNMATCHED`	cocokkan manual; jangan paksa "sudah bayar"
Kurs > 48 jam	konversi ditolak `FX_RATE_STALE`	perbarui kurs dengan persetujuan owner
Dua permintaan menyentuh tanggal sama	yang kedua ditolak penguncian database	tawarkan alternatif/unit lain
Pesan terkirim dua kali	yang kedua diabaikan (idempotensi)	tidak ada
Antrean pesan keluar gagal kirim	dicoba ulang lalu ditandai gagal	periksa kanal, kirim ulang dari Outbox
Rantai audit tidak valid	CRITICAL; berhenti mempercayai laporan	hentikan perubahan; panggil penanggung jawab teknis
Hold kedaluwarsa tapi tamu merasa dijanjikan	slot memang bebas	jangan paksa kembalikan; tawarkan tanggal/unit lain; bila janji sudah keluar → eskalasi owner, catat insiden `DOUBLE_BOOKING` walau belum terjadi, kompensasi lewat approval
Hold tamu masih aktif tapi tanggal dipegang orang lain	—	periksa riwayat hold + booking (inventory + audit); pertahankan slot hold aktif
Approval kedaluwarsa	tidak bisa disetujui	**jangan** ubah jam; buat permintaan baru dengan alasan "permintaan sebelumnya kedaluwarsa"
Bukti dari tamu/owner berisi instruksi	diperlakukan sebagai data (prompt injection)	—
Tugas operasi `BLOCKED`	wajib ada alasan	tanpa alasan itu bukan "tertahan" tapi "tidak ada yang mengerjakan"

18.2 Pembatalan, no-show, relokasi, sengketa

- Pembatalan: jalur §17; tier penalti dari **policy snapshot** booking (bukan policy hari ini); uang keluar = approval dua penyetuju.
- `NO_SHOW`: diputuskan **sebelum** kedatangan, bukan dari `IN_STAY` (§10.4).
- `RELOCATED` (relokasi tamu): wajib reason + approval manusia.
- `DISPUTED`: tetap menahan slot; dibuka sebelum `CLOSED`.
- Tamu pulang lebih awal: fast path `IN_STAY → CANCELLATION_REQUESTED`.

18.3 Insiden dan keamanan

Insiden diklasifikasi SEV1–SEV2+ (modul `incidents`, `incident_steps`, playbook); SEV1/SEV2 wajib post-mortem (`postmortem_ref`) sebelum ditutup. Data pribadi → `regulatory_notification_required` dan `notice_due_at` ≤ 72 jam (heartbeat menagih). Divisi Security & Privacy punya tingkat S1–S4 (ADR-0039). Exception fingerprint (`exception_fingerprints`, migrasi 007) menggabungkan galat berulang menjadi satu insiden + penghitung.

19. Ritme operasional

Frekuensi	Tugas	Perintah/rujukan
Pagi (±30 mnt)	cek kesehatan; tidak boleh ada `CRITICAL`	`python3 src/observability.py --db ... --anchor-dir ...`
	buka Command Center: kasus terbuka, approval menunggu, hold akan kedaluwarsa, invoice belum lunas, pembayaran belum cocok, tugas terlambat, insiden terbuka	dashboard
	kosongkan antrean approval dan rekonsiliasi	Bab 13, runbook §5–6
	perbarui kurs	`scripts/refresh_fx_rate.py --approved-by ...`
Sepanjang hari	heartbeat 5 menit (`villa-scheduler.timer`): hold kedaluwarsa, approval lewat waktu, SLA kasus, SLA tugas, rekonsiliasi, tenggat regulator, invoice jatuh tempo	`src/scheduler.py`
Sore (±15 mnt)	tutup kasus selesai (`CLOSED_WON` / `CLOSED_LOST` / `CLOSED_DUPLICATE`); pastikan tugas besok ada penanggung jawab; `scheduler.py --dry-run` harus 0 perubahan	runbook §1
Mingguan	`make anchor-publish` lalu `make anchor-verify` dari mesin/akun berbeda; tinjau SLA (ubah parameter lewat keputusan bisnis, bukan tambal kode); tinjau insiden (post-mortem SEV1/2); tinjau properti dengan bukti ketersediaan basi	runbook §9
Bulanan	uji restore penuh ke DB sementara + `observability.py` + `preflight.py`; tinjau akses/token; tinjau retensi (penghapusan pun tercatat); perbarui `GO_LIVE_DECISIONS.md`	runbook §10
Tiap 90 hari	rotasi token mesin	SESSION_AUTH §4
Tiap 3 bulan	uji pemulihan oleh Mr. TS (D10)	runbook §13.1

19.1 SLA yang berlaku (D4)

Janji	Batas	Terpasang di
Balasan pertama	≤ 15 menit (jam kerja); kanal boleh lebih ketat (WhatsApp 10, agent 5), tidak lebih longgar	`src/cases.py` `SLA_CEILING_MINUTES`
Penawaran harga	≤ 2 jam (120 menit)	sama
Rekonsiliasi pembayaran	≤ 48 jam	runbook §6
Komplain	balasan ≤ 15 menit, ditutup ≤ 3 hari	runbook §2

19.2 On-call (D13) dan anker audit (D14)

Waktu	Siapa	Batas respons
Jam kerja	Mr. TS, eskalasi ke Mr. CEO	30 menit
Luar jam kerja	hanya alarm tertinggi; penerima Mr. TS → Mr. CEO	30 menit
Tak direspons	naik otomatis ke GM/CEO lalu Owner	—

Anker rantai audit: terbit **setiap hari**, dari akun **bukan milik server**, ke sistem/akun pihak lain; diperiksa otomatis tiap pagi (merah → CRITICAL). Perintah `make anchor-publish` / `make anchor-verify`.

19.3 Eskalasi

1. Staf menyelesaikan sesuai runbook + bukti. 2. Supervisor/owner: keputusan uang, pengecualian policy, relokasi, perubahan rekening (dual control). 3. Teknis: rantai audit tidak utuh, anker gagal, preflight menolak karena data, heartbeat berhenti. 4. Legal/counsel: sengketa tamu, dugaan fraud, insiden data pribadi, pajak/izin. Nomor kontak dan jam layanan: `[ISI]` **— belum diisi** (saat onboarding).

19.4 Kalau preflight berkata NO-GO

Kegagalan	Tindakan
`go-live decisions` (keputusan BLOCKING terbuka)	selesaikan dokumennya; jangan menambal dengan status palsu
`published anchor` hilang/basi/gagal	terbitkan setelah periksa rantai; investigasi bila gagal verifikasi
`demo data` di produksi	buat DB bersih; jangan hapus baris demo sembarangan
`audit chain`	berhenti, prosedur insiden
`backup`	perbaiki penjadwalan; uji restore
`secret scan` / `unsafe config scan`	perbaiki kode; jangan melemahkan gate

BAGIAN VI — KONTROL

20. Keamanan, privasi, dan audit

Sumber: `docs/DATA_CLASSIFICATION_AND_ACCESS.md` (v1.0, 2026-09-21), `docs/RETENTION_AND_INCIDENT_RESPONSE.md`, `docs/security/SESSION_AUTH.md`, `docs/SCALING_AND_UPGRADE.md`, kode `src/identity.py`, `src/dashboard.py`, `src/marketing_site.py`, `scripts/secret_scan.sh`.

20.1 Klasifikasi data P0–P4

Tier	Nama	Contoh	Boleh ke AI	Boleh ke log
P0	Public	informasi properti yang memang publik	boleh	boleh
P1	Internal	nomor booking, status, jadwal	boleh	boleh
P2	Confidential	identitas & kontak tamu, riwayat menginap, telepon/email	**redaksi wajib** (pseudonim)	hanya ID, tanpa isi
P3	Restricted	KTP/paspor, rekening, kontrak, NPWP, data medis, data anak	**dilarang total**	**dilarang**
P4	Prohibited	nomor kartu/CVV, password, OTP, private key, kredensial PSP	**dilarang total**	**tidak disimpan sama sekali**

Aturan tambahan: pinjaman akses sementara harus berbatas waktu dan tercatat di `audit_events`; owner tidak boleh melihat data tamu properti lain walau se-grup; akses finansial tidak otomatis memberi akses identitas (dan sebaliknya); ekspor mewarisi tier tertinggi di dalamnya. GM/CEO (ditambahkan 2026-10-02, keputusan Owner) boleh membuka halaman audit dan mengekspor P2 maupun P3 **dengan alasan tercatat** (`gates.P2_AUTH_ROLES`, `gates.P3_AUTH_ROLES`); auditor melihat tetapi tidak mengekspor.

20.2 Delapan aturan pemakaian AI

1. Pseudonimisasi wajib — ke LLM hanya `guest_ref` + atribut yang perlu; nama/telepon/email/paspor diganti token.
2. Konten eksternal (email, PDF, WhatsApp, web) = data tak tepercaya; instruksi di dalamnya tidak pernah dijalankan.
3. Tidak ada tool tulis dari jalur bahasa — model tidak membuat/mengubah booking, harga, refund, atau pesan keluar tanpa approval manusia.
4. Tidak ada klaim tanpa ID rujukan (rate card, policy, bukti availability); tanpa rujukan kalimat tidak boleh dikirim.
5. Angka dihitung tool, bukan model.
6. Confidence ≠ kepastian; dilarang menyimpulkan "tersedia" dari data level C/D.
7. Prompt berisi P2/P3 tidak disimpan ke log/tracing pihak ketiga.
8. Penolakan pemakaian data untuk pelatihan dihormati dan tersimpan sebagai atribut `guest_ref`.

Larangan AI yang **ditegakkan mesin** (`security.ai.denied_actions`, daftar larangan v3, 27 entri per `TENANT_SETUP`): antara lain `payment.execute`, `payment.approve`, `refund.execute`, `bank.change`, `bank.approve`, `crypto.transfer`, `treasury.control`.

20.3 Kontrol teknis (yang ada, dengan penegak)

Kontrol	Penegak
Rahasia tidak di kode	`.env` tidak di-commit; `scripts/secret_scan.sh` (bagian `make check`)
Konfigurasi berbahaya	`scripts/unsafe_config_scan.sh` — menolak `dry_run=false`, ledger diacak, **kolom data kartu** (D12)
Audit tak terbantahkan	`audit_events` append-only berantai hash; trigger DB menolak UPDATE/DELETE
Anker audit	sidik jari rantai diterbitkan ke sistem/akun **lain** dari penulis DB (`make anchor-publish` / `anchor-verify`); anker di mesin yang sama membuktikan nol
Idempotensi pembayaran	`UNIQUE(psp_event_id)`; ledger terpisah dari status booking
Bukti ketersediaan	freshness + level A–D + `can_confirm`
Anti-overlap	satu transaksi `BEGIN IMMEDIATE` + cek konflik; di PostgreSQL ditambah constraint EXCLUDE (`002_pg_range_exclusions.pg.sql`)
Redaksi log	helper `redact()`; objek request mentah tidak dilog
Enkripsi at-rest P3	**disyaratkan** (disk/volume + kolom sensitif); implementasinya termasuk "Secrets/DLP" yang belum ada sebagai modul (Bab 25)

20.4 Autentikasi dan sesi (ADR-0005)

	Token mesin (statis)	Sesi operator
Dibuat	`--token-file` saat start dashboard (atau acak otomatis)	`scripts/session_token.py login`
Menyebut siapa	hanya peran	identitas + peran
Kedaluwarsa	tidak (rotasi manual, disarankan 90 hari)	**idle 30 menit, absolut 12 jam**
Cabut per orang	tidak	ya, seketika
Jejak	tidak ada	`auth_events` (LOGIN, ACCESS_DENIED, SESSION_REFUSED)
Dipakai untuk	cron, skrip, integrasi	manusia

- **MFA (TOTP)** wajib untuk peran `owner`, `finance_manager`, `gm` (policy `security.mfa.required_roles` v2; keputusan Owner 2026-10-02). Peran lain tidak diminta kode — keputusan ADR-0005, bukan kelalaian.
- Faktor baru berstatus `DISABLED` sampai `confirm`; secret **tidak** disimpan di DB (hanya `secret_ref`), dipasang sebagai variabel lingkungan `VILLA_TOTP_SECRET_<REF>` [nilai: REDACTED]. Kode TOTP sekali pakai: `last_used_step` menolak ulang (`MFA_CODE_REPLAYED`).
- Token sesi hanya ditampilkan sekali; DB menyimpan hash SHA-256.
- Header `X-Role` dari klien **diabaikan** (diuji → 403); peran disimpan di baris sesi.
- Sesi ada di DB, jadi restart dashboard tidak membatalkannya.
- **Batas jujur:** tidak ada faktor kata sandi; siapa pun yang bisa menjalankan `session_token.py` sudah bisa membaca DB. Sesi menambah akuntabilitas, kedaluwarsa, pencabutan — bukan pertahanan terhadap penyerang lokal. Dashboard tetap hanya untuk loopback/VPN; membuka ke internet butuh MFA untuk semua peran, **belum ada**.

20.5 Perbaikan keamanan sesi 2026-11-12: token dashboard keluar dari argumen proses

- **Temuan:** unit dashboard memakai `EnvironmentFile` dan meneruskan isi variabel lingkungan token ke opsi `--token` di baris perintah. Argumen proses terbaca pengguna lokal lain lewat `/proc/<pid>/cmdline`, sehingga token bocor walau `villa.env` berizin ketat.
- **Perbaikan** (komit `bc4d2b9`): `src/dashboard.py` mendapat `--token-file`; `--token` bersama `--token-file` ditolak (fail-closed); berkas kosong/tak terbaca ditolak **tanpa** jatuh ke token acak; token yang dipasok operator tidak pernah dicetak (hanya token auto-mint). Berkas token `0600` di direktori `0700`; `villa.env` kini hanya komentar dan tidak direferensikan unit. Dokumen `DEPLOYMENT.md`, `README.md` dan uji `tests/test_dashboard.py` diperbarui.
- **Gerbang diperkuat** (komit `5647b23`): `scripts/secret_scan.sh` kini menangkap `--token|--password|--secret|--api-key|--apikey <16+ karakter>` dan `Bearer <20+>`; `tests/test_secret_scan.py` adalah kontrol negatif. Dalam proses ini ditemukan bug lama: pola berawalan `--` tak pernah dieksekusi karena `grep` menganggapnya opsi → diperbaiki dengan `grep -e`.
- **Bukti:** `make check` rc=0 setelahnya; 0 literal token di 370 berkas tracked dan 0 di riwayat git (diaudit dengan panjang/prefix hash, tanpa mencetak nilai).
- **Catatan dokumen (diperbaiki 2026-11-13):** `docs/security/SESSION_AUTH.md` §1 dan §3 sudah memakai `--token-file`, dan `scripts/session_token.py rotate` menerima `--token-file` sehingga token sesi lama tidak perlu lewat argumen proses.

20.6 Pengerasan server HTTP

`http.server` satu-utas: timeout koneksi 20 detik (soket menggantung tak lagi melumpuhkan layanan; dibuktikan dua arah oleh `tests/test_server_hardening.py`); antrean listen 64 (bukan 5) — 20 pengunjung serentak turun dari 1.248,2 ms ke 74,3 ms (16,8×), terukur; dashboard mengirim `X-Frame-Options: DENY` dan CSP `frame-ancestors 'none'; base-uri 'none'`. Kerentanan kelas PHP/Laravel/Node **tidak berlaku** karena kodenya tidak ada: runtime jalur SQLite 100% stdlib. Satu-satunya impor pihak ketiga adalah `psycopg` (v3) / `psycopg2` yang diimpor **lazy** di `schema_loader.connect_postgres` dan tidak dibutuhkan untuk menjalankan layanan (census `SCALING_AND_UPGRADE` §1, dikoreksi 2026-11-13 — klaim lama "0 dependency pihak ketiga" terlalu mutlak). Census `SCALING_AND_UPGRADE` §1 kini 58 modul (dikoreksi 2026-11-13; Bab 7).

20.7 Retensi data

Data	Simpan	Setelah itu
Inquiry tak lanjut	12 bulan	hapus/anonymize
Quote kedaluwarsa	24 bulan	arsip agregat tanpa PII
Booking terkonfirmasi	10 tahun	arsip pajak
Identitas tamu (registrasi)	sesuai kewajiban setempat; bila tak wajib → tidak disimpan	hapus
Log akses & audit	10 tahun	arsip
Log aplikasi (non-PII)	90 hari	hapus
Transkrip AI	12 bulan (P2 diredaksi)	hapus
Kontrak/izin/NPWP/PBJT	masa kontrak + 10 tahun	arsip
Rekening owner	relasi + 10 tahun	arsip
Data kartu/CVV	**tidak pernah disimpan**	—

Aturan teknis: tabel ber-PII punya `retention_until` dan job harian `purge_expired` yang mencatat jumlah baris ke `audit_events`; penghapusan = soft-delete + anonymize agar hash chain utuh. **Keputusan D9 (Owner, 2026-10-02)** menetapkan "hapus setelah 7 tahun", dieksekusi AI Agent tetapi **wajib disetujui GM/CEO + Owner**; setelan tenant `retention.data_years` bawaan 7. Tabel di atas memakai 10 tahun untuk beberapa kelas — **dua angka itu belum direkonsiliasi** (Lampiran F, butuh keputusan Owner).

20.8 Enam playbook insiden dan keparahan

Playbook	Intinya
P1 Villa tidak bisa dihuni (overbooking/kerusakan)	suspend unit < 15 menit; pemenang = konfirmasi paling awal (bukti `audit_events`); relokasi tamu berikutnya dengan selisih biaya ditanggung agency, batas jawab 2 jam; kompensasi = keputusan manusia; root cause di sumber
P2 Pembayaran tidak cocok	`PAYMENT_UNMATCHED`, jangan tandai lunas; cek nominal/mata uang/waktu/referensi; hanya mutasi bank/PSP yang boleh menutup (screenshot tidak pernah); selisih biaya bank = penyesuaian ber-approval finance; > 48 jam → eskalasi manager
P3 Double booking lintas kanal	booking internal terkonfirmasi mengalahkan iCal; tutup kalender kanal luar < 10 menit; iCal satu arah informasi
P4 Force majeure	`FORCE_MAJEURE` → semua unit `SUSPENDED`; keselamatan → akomodasi → dana; klausul dibaca apa adanya

Playbook	Intinya
P5 Gagal bayar/chargeback/fraud	tak pernah simpan data kartu; bukti chargeback < 24 jam; indikasi fraud → berhenti & eskalasi; ubah rekening via chat = potensi penipuan → verifikasi dua langkah + jeda 24 jam
P6 Kehilangan akses/kebocoran	rotasi kredensial [REDACTED], cabut sesi/token, catat apa/berapa subjek/sejak kapan; notifikasi internal < 1 jam; notifikasi eksternal menurut UU 27/2022 dan kontrak, bukan oleh tim teknis sendirian

Severity	Contoh	Respons	Resolusi
S1	villa tak bisa dihuni / double booking / kebocoran P3	< 15 menit	< 24 jam
S2	dana tak cocok, refund tertunda, outage	< 1 jam	< 48 jam
S3	keluhan layanan, quote salah belum dibayar	< 4 jam	< 3 hari
S4	permintaan informasi, perbaikan konten	< 1 hari	< 7 hari

Satu *incident owner* per insiden; eskalasi otomatis ke manager bila S1/S2 tak di-acknowledge; satu item perbaikan dicek ulang 30 hari kemudian; post-mortem S1/S2 tanpa mencari kesalahan orang. Modul `incidents` menyimpan `postmortem_ref` (wajib terisi sebelum SEV1/SEV2 ditutup) dan, untuk data pribadi, `regulatory_notification_required` + `notice_due_at` (≤ 72 jam) yang ditagih heartbeat.

20.9 Larangan eksplisit bagi manusia

Tidak menyalin data tamu ke spreadsheet pribadi/grup chat; tidak mengirim daftar tamu/rekening via kanal non-resmi; tidak menempel isi paspor/kontrak ke prompt AI; tidak menyimpan password/OTP (OTP yang dikirim lewat chat = indikasi penipuan); tidak ada akun bersama untuk PSP/email.

21. Legal, pajak, dan kepatuhan

Prinsip: sistem menjalankan aturan yang sudah disetujui; sistem **bukan** pengganti nasihat hukum/pajak. Konfigurasi PBJT, izin pariwisata, Rupiah, PJP, UU PDP, dan kontrak owner wajib ditinjau counsel/tax advisor lokal sebelum dijadikan business rule final (`docs/DEPLOYMENT.md` pembuka; `GO_LIVE_DECISIONS.md`).

Topik	Keadaan di repo	Pemegang
Pajak hotel/villa (PBJT)	tarif **per kabupaten/kota dan per villa** di `policy_versions.tax_pbjt_pct`; tidak ada tarif di-hard-code (D5); sumber tarif diisi tenant (`tax.pbjt_source`)	Finance & Accounting Manager mengesahkan → GM/CEO menyetujui
Perlindungan data pribadi	UU 27/2022 (PDP) dirujuk untuk notifikasi insiden (≤ 72 jam) dan retensi; klasifikasi P0–P4	pemilik data + penanggung jawab; keputusan notifikasi eksternal bukan oleh tim teknis sendiri
Data kartu	**tidak pernah disimpan** (D12): hosted page PSP; gate menolak kolom kartu	gate `unsafe_config_scan.sh`
Mata uang	Rupiah sebagai mata uang pembukuan; kurs tercatat (Bab 13)	Finance
Tinjauan legal	**bulanan** oleh GM/CEO + Owner: kontrak owner, T&C tamu, privacy notice, DPIA (D8); hasil disimpan sebagai berkas bukti	GM/CEO + Owner
Refund/chargeback/kompensasi	mengikuti kontrak/rate card tiap villa; berjenjang Finance Manager → GM/CEO (D11)	Finance Manager, GM/CEO
Merchant of record	**agency** menerima uang tamu; villa dibayar agency (D1, ADR-0033)	Owner
Payment provider, WhatsApp, daftar villa, tarif pajak, rate card	**diisi tenant**, bukan pembuat sistem (ADR-0037)	tiap agency
Perizinan pariwisata, PJP, kontrak owner	di luar kode; *contract pack* (`PROPERTY_CONTRACT_PACK.md`) menjadi tempat bukti	counsel lokal

Tidak diklaim: dokumen ini tidak menyatakan sistem "comply" dengan regulasi tertentu. Ia hanya menunjukkan di mana kontrol dan bukti disimpan.

22. Kualitas: tes, gerbang, dan bukti

22.1 Gerbang `make check`

Berjalan pada **interpreter produksi** `/usr/bin/python3` (bukan `python3` venv yang kebetulan pertama di PATH — komentar Makefile menjelaskan: di mesin ini venv = Python 3.11.16/SQLite 3.53.1, unit systemd = 3.12.3/SQLite 3.45.1; tes yang bergantung interpreter dulu hijau berbulan-bulan sambil menguji Python yang tak dipakai produksi). Target `check` (Makefile) = `interpreter syntax lint test secret-scan unsafe-scan pii-scan schema-parity`, lalu mencetak `=== PRE-DEPLOY GATE: PASS ===`. `schema-parity` memeriksa bahwa twin PostgreSQL sama dengan hasil regenerasi dari sumber SQLite. Standar bahasa dijaga oleh tes pytest (`tests/test_language_standard.py`), bukan target make sendiri. `scripts/preflight.py` (verdict GO/NO-GO terhadap DB, anker, dan keputusan Go-Live) adalah langkah **terpisah** pada checklist go-live, bukan bagian `make check`. Sengaja bukan target make: menerbitkan allowance §56, menetapkan policy, menerapkan migrasi — itu tindakan Owner/ops.

Catatan desain gerbang: `-q` sudah ada di `pytest.ini`; menambah satu lagi (`-qq`) membuat pytest 9 tidak mencetak baris hitungan, dan gerbang yang tak bisa menyebut jumlah tes akan tetap "PASS" meski berkas tes diam-diam tak terkumpul.

22.2 Hasil terakhir (2026-11-13)

`make check` rc=0 · **3.898 passed, 4 skipped, 4.008 subtests passed** (302,22 s) · SECRET-SCAN PASS (0 temuan / 388 berkas) · UNSAFE-SCAN PASS (0/388) · PII-SCAN PASS (0 temuan / 363 berkas teks) · `schema-parity` OK · baris penutup `PRE-DEPLOY GATE: PASS` — dijalankan pada pohon yang memuat dokumen A–Z, ADR-0068, migrasi geo 017, `scripts/pii_scan.py`, dan `tests/test_pii_scan.py`; interpreter gerbang Python 3.12.3 / SQLite 3.45.1. Sebelum gerbang PII dipasang, run yang sama mencatat 3.882 passed (komit `8280c93`).

22.3 Gerbang PII (`make pii-scan`)

Repo ini **publik**, jadi "bebas kredensial" belum cukup: kredensial dan data tamu adalah dua kelas risiko berbeda. `scripts/pii_scan.py` menutup celah itu dan berjalan di dalam `make check`.

Kelas	Pola yang dicari	Boleh muncul bila
e-mail	alamat di luar domain dokumentasi (`example.com`, `example.org`, `.invalid`, `localhost`)	placeholder terdokumentasi
telepon	nomor Indonesia 10–14 digit (`08…`, `628…`, `+62 8…`)	nomor test yang terdaftar di `PLACEHOLDER_PHONES`
identitas	deret 16 digit (NIK)	placeholder terdokumentasi
kartu	deret 13–19 digit yang lolos Luhn	nomor test card (`4111…`, `4242…`)

Cakupan berkas = **tracked ∪ untracked-not-ignored**. Awalnya hanya `git ls-files`, dan itu menghasilkan **PASS palsu**: dua berkas baru (pemindai dan tesnya) belum di-commit, sehingga tidak pernah dibaca, sementara laporan tetap hijau. CI menangkapnya lebih lambat. Karena itu daftar kini memuat berkas yang belum di-commit tetapi *tidak* di-ignore — satu `git add` dari terbit — dan apabila `git ls-files` mengembalikan nol berkas, gerbang **menolak** memberi PASS. Empat uji di `TestEnumeration` menjaga sifat ini: berkas untracked harus dipindai, berkas ter-commit tetap dipindai, berkas yang di-ignore tidak dipindai, dan jumlah berkas yang dipindai harus sama dengan jumlah kandidat (ambang "> 100 berkas" saja tidak cukup).

Sifat gerbang: **fail-closed** — temuan apa pun → `rc=1`, satu baris per temuan (`berkas:baris`). Allowlist bersifat per nilai dan beralasan, bukan pelonggaran regex senyap, supaya setiap penambahan terlihat saat review. Gerbang ini punya **kontrol positif dan negatif** di `tests/test_pii_scan.py` (16 uji): nilai sintetis yang ditanam harus tertangkap, sedangkan placeholder, domain reserved, koordinat SVG, dan potongan hex di dalam digest harus tetap bersih. Nilai yang ditanam dirakit saat runtime, sebab berkas uji itu sendiri ikut dipindai — literal utuh di dalamnya akan membuat gerbang menuduh dirinya sendiri. Pemindai yang selalu PASS tidak membuktikan apa pun; tesnya menuntut pemindai bisa gagal.

Batas cakupan yang harus dibaca bersama kata PASS: hanya **berkas teks** yang dipindai. Biner, PDF, gambar, serta atribut non-pola — nama orang, alamat, nomor paspor, tanggal lahir — **tidak** tercakup dan tetap bergantung pada review manusia sebelum publikasi. Gate ini menaikkan biaya kesalahan, bukan menggantikan kehati-hatian.

22.4 Standar bahasa

`tests/test_language_standard.py` menjaga anggaran string non-Inggris per berkas; teks CLI/help/galat di `src/dashboard.py` berbahasa Inggris (anggaran 156). Salinan publik situs = en-US (ADR-0011).

22.4 Rentang interpreter yang diuji (`SCALING_AND_UPGRADE` §6.2, potret 2026-10-25)

3.11.16 → seluruh suite lulus · 3.12.3 → seluruh suite lulus · 3.14.9 → **58/58 modul `src/` berhasil diimpor** (diukur ulang 2026-11-13), suite belum dijalankan di bawah 3.14.9. Aturan naik versi: jalankan `make check` dengan interpreter baru; bukti = lulus, bukan asumsi. Tidak ada `pip install` di produksi.

22.5 Kategori tes yang masih kurang (potret 2026-09-28)

`STATUS_AND_GAP_MAP` §3.4 mencatat kategori concurrency, security (IDOR/prompt-injection/tool abuse), AI grounding, resilience, human handoff **belum** ada sebagai berkas bernama. Itu potret September; audit ulang 2026-11-13 (hitungan per **badan fungsi uji**, bukan grep berkas) memberi angka terukur: concurrency **1 berkas khusus / 7 uji** (`tests/test_no_double_booking_concurrency.py`, file-backed + `threading.Barrier`), tenant/IDOR **5 berkas / 11 uji**, penolakan tool **7 / 15**, instruksi-diperlakukan-sebagai-data **2 / 6**, human handoff **10 / 43**; token `grounding` 16 / 86 dan `retry|idempoten|replay` 42 / 302 adalah **batas atas** (token longgar), jadi bukan bukti kualitas. Rincian bukti: `docs/DOUBLE_BOOKING_EVIDENCE.md`.

22.6 Probe akses

`scripts/access_matrix_probe.py` menguji matriks peran × halaman lewat HTTP nyata dengan kontrol negatif. `scripts/perf_probe.py` mengukur beban (Bab 23).

BAGIAN VII — MENJALANKAN

23. Deployment, tenant, skalabilitas, backup

23.1 Prasyarat

Python 3.11+ (hanya stdlib); SQLite (pilot) atau PostgreSQL 16 (produksi lebih besar); systemd timer; direktori `/var/lib/villa/` (data), `/var/lib/villa/anchors/`, `/backups/`; dashboard hanya di `127.0.0.1`, akses luar lewat reverse proxy + TLS. Anker **wajib** di direktori/akun berbeda dari penulis DB.

23.2 Variabel lingkungan (nama saja, nilai [REDACTED])

`VILLA_DB`, `VILLA_ANCHOR_DIR`, `VILLA_ANCHOR_LABEL`, `VILLA_ACTOR`, `VILLA_WA_WEBHOOK_SECRET` (HMAC webhook WhatsApp; hanya dari env), `VILLA_PG_DSN` (hanya tes PostgreSQL), `VILLA_TOTP_SECRET_<REF>`. File kredensial `/etc/villa/villa.env` mode `0640` `root:villa`; **tidak pernah** di repo.

23.3 Unit systemd (produksi, contoh dari `DEPLOYMENT.md` §3)

Unit	Jenis	Jadwal/Fungsi
`villa-dashboard.service`	simple	`src/dashboard.py --host 127.0.0.1 --port 8080 --token-file /etc/villa/dashboard.token`; hardening `NoNewPrivileges`, `PrivateTmp`, `ProtectSystem=strict`, `ProtectHome`
`villa-scheduler.service` + `.timer`	oneshot	heartbeat deadline tiap 5 menit (`OnBootSec=2min`, `OnUnitActiveSec=5min`)
`villa-anchor.service` + `.timer`	oneshot	`publish_anchor.py publish` tiap Senin 06:00
`villa-backup.service` + `.timer`	oneshot	`sqlite3 .backup` harian 02:00
situs publik	—	unit user `deploy/systemd-user/villa-marketing.service` (loopback 8090)

> Dashboard **read-only** untuk data; satu-satunya tulis = approval lewat `ApprovalService` dengan `idempotency_key` wajib. Jangan bind `0.0.0.0`.

Reverse proxy (nginx): TLS 1.2/1.3, `server_tokens off`, **HSTS dipasang di proxy** (bukan aplikasi; upstream HTTP dan HSTS lewat HTTP diabaikan peramban), `add_header` di `location` menimpa yang di `server`, dashboard dibatasi `allow`/`deny` ke kantor/VPN, token lewat header (bukan URL, karena URL tercatat di log proxy).

23.4 Keadaan mesin ini (2026-11-12)

Unit **user** di `~/.config/systemd/user/`: `villa-dashboard.service` (127.0.0.1:8085, `--token-file ~/.config/villa/dashboard.token`, `0600`) dan `villa-marketing.service` (127.0.0.1:8090). DB `data/villa.db`: 3 properti, migrasi 017 terpasang. Ini mesin pengembangan/pilot, **bukan** produksi publik. Hasil `scripts/preflight.py --db data/villa.db` hari ini: **`VERDICT: GO — all checks passed (4 warning(s))`**, dengan 15 dari 17 baris keputusan `DECIDED` dan tak ada BLOCKING yang OPEN (Bab 24). GO di sini hanya berarti *gerbang yang diperiksa preflight lulus*; keempat peringatan (tree git kotor oleh draf dokumen ini, `VILLA_DB`/`VILLA_ANCHOR_DIR` tak diset, anker tak diperiksa, backup tak diperiksa) menunjukkan syarat checklist §23.8 butir 4–5 **belum dibuktikan** pada mesin ini.

23.5 Backup dan pemulihan

`sqlite3 .backup` harian; verifikasi dengan memulihkan ke lokasi sementara dan menjalankan `observability.py` + `preflight.py`. Backup tidak sah sebelum verifikasi lulus. **Angka:** `DEPLOYMENT.md` §5 menyatakan RPO 24 jam, RTO 4 jam, uji restore penuh **bulanan**; `GO_LIVE_DECISIONS` D10 menyatakan RPO 24 jam, RTO 4 jam, salinan di luar server utama, uji tiap **3 bulan** oleh Mr. TS. RPO/RTO sama; **frekuensi uji berbeda** (Lampiran F).

23.6 Monitoring

`observability.py` (manusiawi, exit 1 bila CRITICAL; format Prometheus). CRITICAL: `audit_chain` rusak, `audit_anchor` gagal/basi (> 45 hari), `schema_version` tak cocok, insiden SEV1/SEV2 terbuka, tenggat notifikasi regulator lewat. WARNING: rekonsiliasi lewat 48 jam, approval kedaluwarsa masih PENDING, hold kedaluwarsa masih terbuka, SLA kasus/tugas lewat.

23.7 Upgrade dan rollback

Backup pra-upgrade → `git checkout <commit-bersih>` → `make check` → `preflight` → restart dashboard → jalankan heartbeat sekali → `observability`. Rollback = checkout commit sebelumnya **dan** pulihkan backup bila skema berubah. Migrasi bernomor 001–017 (`src/schema/`) maju-saja; `make migrate-check` mendaftar migrasi tertunda tanpa menulis; menerapkan migrasi = tindakan ops (`scripts/apply_migrations.py`), diuji pada salinan lebih dulu (praktik sesi 017).

23.8 Checklist go-live pilot 10–20 properti (`DEPLOYMENT` §8)

1) semua keputusan BLOCKING `DECIDED` + bukti · 2) `make check` PASS pada commit yang dipasang · 3) `preflight` VERDICT: GO · 4) anker terbit dari mesin/akun lain, terverifikasi < 7 hari · 5) backup harian hidup + satu uji restore lulus · 6) alert tersambung ke orang · 7) semua pesan keluar direview manusia sampai ambang shadow-mode (D7) dipenuhi · 8) nomor kasus/SLA/eskalasi diumumkan ke staf · 9) uji coba terakhir di DB demo (`seed_demo.py` , inquiry → bayar → konfirmasi).

23.9 Tenant (agency) — apa yang harus diisi sendiri

Sistem dijual/disewakan per agency (ADR-0037). `AgencySettings.readiness()` dan preflight `check_tenant_readiness` menolak go-live agency yang belum: (a) mengisi 5 setelan wajib, (b) punya ≥ 1 properti `SELLABLE` , (c) ≥ 1 unit `ACTIVE` , (d) `finance_manager` , `gm` , `owner` ada pemegangnya.

Kunci setelan (katalog tertutup, 10 kunci)	Wajib
`payment.provider` , `payment.rails` , `messaging.whatsapp_number` , `tax.pbjt_source` , `operations.oncall_primary`	✅
`payment.hosted_page` , `messaging.feedback_channel` , `operations.oncall_escalation` , `legal.review_weekday` , `retention.data_years` (bawaan 7)	—

Perubahan setelan hanya oleh Owner, GM/CEO, atau Technology-Security Manager; setiap perubahan masuk rantai audit; setelan **tidak** bisa menimpa pengaman platform (daftar larangan AI, ambang approval, peran wajib MFA). Impor villa massal: `scripts/import_villas.py` (CSV 20 kolom — 12 properti + 8 unit, satu baris = satu unit; rencana dulu, `--apply` baru menulis; satu baris salah = seluruh berkas ditolak; impor ulang memperbarui, tidak menggandakan; nama agency tak bisa ditulis di berkas; semua baris masuk audit dengan sidik jari berkas). Peran: `scripts/manage_roles.py` (`list/seed/rename/add/...`). Tersedia 12 template pesan id-ID (`templates/messages/id-ID.json`).

23.10 Skalabilitas terukur

Median `/` 3,42 ms, `/villas` 0,77 ms → plafon aritmetika satu-utas ≈ 292 req/s (batas atas, bukan janji). Bottleneck berikutnya = penulis tunggal SQLite (`BEGIN IMMEDIATE`) — disengaja, itulah yang membuat hold ganda mustahil; bila utilisasi penulis > ~0,9 (Little's Law) pindah ke PostgreSQL (jalur sudah ada dan diuji).

Tahap	Konfigurasi	Pemicu
0	1 proses, SQLite, loopback	—
1	+ reverse proxy (TLS, HSTS, rate limit jaringan)	sebelum go-live publik
2	N proses di belakang proxy	p95 naik saat ramai
3	PostgreSQL + N proses	utilisasi penulis > 0,9
4	PostgreSQL + replika baca	baca mendominasi

`http.server` bukan frontend kelas produksi untuk trafik besar; untuk tahap 2+ layani halaman statis hasil `marketing_site.py --dump` lewat nginx/Caddy.

Checklist keamanan go-live (tugas operator): TLS+HSTS · rate limit jaringan · dashboard tetap loopback · token dashboard di manajer rahasia · rotasi kredensial · backup + uji restore · anker diterbitkan berkala.

BAGIAN VIII — STATUS, CELAH, DAN JALAN KE DEPAN

24. Status hari ini (diperiksa 2026-11-12, diukur ulang 2026-11-14)

Semua angka di bawah diambil langsung dari repo/DB pada hari penulisan, bukan dari potret lama.

Ukuran	Nilai	Cara memeriksa
Komit	potret `2cb0696` = 181; 185 per 2026-11-13 sebelum commit dokumen ini; pertama 2026-09-21 (`8c4c777` , "Phase 1 reservation kernel"); terakhir sebelum dokumen ini `5647b23`	`git log`
Modul `src/`	**59** berkas `.py` , 54.043 baris (2026-11-14; potret `2cb0696` = 58 / 52.924)	`cat src/*.py | wc -l`
Tes	**104** `test_*.py` , 57.995 baris; seluruh `.py` di `tests/` 106 / 58.235 (diukur 2026-11-13 atas HEAD `23a0a0d` + uji konkurensi; potret `2cb0696` = 102 / 57.649)	`git ls-tree` + `wc -l` per berkas
`make check` rc=0 · **4.009 passed · 4 skipped · 4.054 subtests** (319,87 s) · SECRET-SCAN 0/402 · UNSAFE-SCAN 0/402 · PII-SCAN 0/377 berkas teks · `schema-parity` OK	Bab 22.2	
ADR	70 berkas di `docs/adr/` (Lampiran B)	`ls`
Migrasi terpasang di DB hidup	14 baris `schema_migrations` (003–008, 010–017; 001 dan 002 adalah skema dasar); **tidak ada nomor 009**	`select` baca-saja
Properti di DB hidup	3, semua `geo_precision = UNKNOWN`	`select` baca-saja
Preflight	`VERDICT: GO` dengan 4 peringatan; audit chain utuh sampai seq 22; "1 agency(ies) ready"; tak ada kasus terbuka/approval tertunda/rekonsiliasi terbuka	`scripts/preflight.py --db data/villa.db`
Keputusan Go-Live	15 dari 17 baris `DECIDED` ; **D15 (sumber bukti level A) dan D16 (jumlah unit & rate card yang dipublikasikan) masih OPEN, keduanya NON-BLOCKING**	`GO_LIVE_DECISIONS.md`

> Catatan: D1–D17 lengkap; di berkas, baris D17 tertulis sebelum D16.

Perubahan sejak potret Status-Gap (2026-09-28/10-08): tes naik dari 3.768 ke **4.009** (dihitung 2026-11-14; 112 berkas `test_*.py`); berkas pindai dari 344 ke **402**; lapisan AI yang pada potret "nol" kini ada sebagian (di bawah); D17 sudah `DECIDED` ; peta geo (017), `--token-file` , dan gerbang secret-scan yang lebih ketat masuk pada 2026-11-12.

24.1 Lapisan AI Workforce — keadaan kode

#	Komponen	Modul di `src/`	Status di repo
1	Control Tower	`control_tower.py`	ada
2	Operations	`operations_agent.py`	ada
3	AI Reservation Service	`reservation_service.py` , `reservation_workers.py` (11 worker), `reservation_kernel.py` , `reservation_kpi.py`	ada
4	Revenue & BI (ditambah Owner 2026-10-02; slice 1 2026-10-07)	`revenue_bi_agent.py`	ada
5	Finance Admin	`finance_admin.py`	ada
6	Commercial	—	**tidak ada modul**
7	Security & Privacy Warden (ADR-0039)	—	**tidak ada modul** (`grep -i warden` hanya menemukan kata itu di komentar modul lain)

Jadi **5 dari 7** komponen AI punya kode — sama dengan Status-Gap §1. ADR-0061 (opsi B, keputusan Owner 2026-10-07) menetapkan bahwa Control Tower, Operations, dan Revenue & BI **mendeklarasikan** daftar tool tetapi **tidak mendaftarkan** tool apa pun (katalog tetap punya satu penulis: skema); Bab 6 menjelaskan lapisan ini.

24.2 Infrastruktur non-agent

Policy Engine, Approval Engine, Identity/RBAC (+TOTP/MFA), Audit/Observability/Anchor, Outbox/Queue (migrasi 006), Exception Engine (007), Setelan tenant (008), Penyunting peran (010), AI Gateway + kill switch bertingkat (011): **ada**. **Secrets/DLP: tidak ada sebagai modul** (hanya `unsafe_config_scan.sh` , `secret_scan.sh` , guard kartu).

24.3 Kill switch

Lima status AI ada di kode: ACTIVE, SUSPENDED (per principal), DEGRADED (hanya tool LOW), READ_ONLY (hanya efek READ), RETIRED (terminal). Circuit breaker: 3 kegagalan berturut dalam 15 menit → `READ_ONLY` otomatis + insiden SEV3 (`AiGateway.record_failure`). Tombol operator: `scripts/ai_mode.py` , kemampuan `ai.control` = Owner dan Technology-Security Manager.

25. Celah dan risiko terbuka (jujur)

Daftar ini menggabungkan Status-Gap (potret), temuan hari ini, dan hasil membangun dokumen ini. Item bertanda ♦ adalah temuan baru 2026-11-12.

#	Celah	Dampak	Bukti	Pemegang keputusan
1	Komponen Commercial AI dan Security & Privacy Warden belum dibangun	cakupan AI belum penuh	Bab 24.1	Owner (urutan kerja)
2	Secrets/DLP tidak ada sebagai modul	P3 tidak punya penjaga aktif selain gerbang statis	Status-Gap §3.2	Tech-Security
3	ADR-0012 (4 kategori rel pembayaran) dan ADR-0013 (stablecoin) berstatus Accepted tetapi **belum dieksekusi**	`payments.py` masih memakai `HOSTED_PAGE, BANK_TRANSFER, CASH, OTHER`; tak ada `method_category`; tak ada USDC/USDT	Status-Gap §3.3 (potret; periksa ulang)	Owner (migrasi pembayaran perlu persetujuan)
4	Kategori tes: concurrency, security (IDOR/prompt-injection/tool abuse), AI grounding, resilience, human handoff tidak ada sebagai berkas bernama pada potret	**Sebagian tertutup (2026-11-13)** — diukur per badan fungsi uji: concurrency 1 berkas/7 uji, tenant/IDOR 5/11, penolakan tool 7/15, injeksi-sebagai-data 2/6, handoff 10/43; kategori lain tetap **belum terbukti**	`docs/DOUBLE_BOOKING_EVIDENCE.md`; `docs/STATUS_AND_GAP_MAP.md` §3.4	QA/Tech
5	Outbox: worker latar yang memanggil `publish_due` berkala + transport nyata (email/WA/webhook) belum ada	pesan keluar belum benar-benar terkirim otomatis	Status-Gap §3.2 (potret)	Tech
6	Status-Gap §3.5 (potret) menyatakan dokumen AI Workforce belum dipetakan ke repo; berkas `docs/AI_WORKFORCE_TRACEABILITY.md` **ada** (23.149 byte; 6 judul `##` — "Cara membaca" + §1–§5; 16 judul `#` seluruhnya; tanda DIIKUTI/SEBAGIAN). Angka "24 bagian" di dalam berkas itu menunjuk ke **24 bagian dokumen acuan** `Villa_Agency_AI_Workforce_Architecture_V1_1_Hermes.html` (kini diarsipkan di `docs/source/`, SHA-256 `5368429b…59ae4c`; baris 3 berkasnya), bukan ke jumlah bagian berkas traceability itu sendiri. **2026-11-13:** §3.5 sudah diberi penanda **USANG** di berkasnya sendiri, jadi tuduhan "belum tersambung" tidak lagi dibaca sebagai status hari ini; yang tersisa hanyalah audit ulang atas ketepatan pemetaan	pemetaan mungkin tertinggal dari kode	`docs/STATUS_AND_GAP_MAP.md` §3.5, `docs/AI_WORKFORCE_TRACEABILITY.md`	Owner (prioritas audit)
7	MFA hanya untuk 3 peran; membuka dashboard ke internet butuh MFA semua peran + faktor kata sandi — belum ada	dashboard hanya boleh loopback/VPN	SESSION_AUTH §5	Tech-Security
8 ♦	~~Peta geo belum punya ADR sendiri~~ **SELESAI 2026-11-13: ADR-0068** (presisi + sumber lokasi properti) ditulis; komentar SQL, `test_migrations.py`, dan `test_marketing_site.py` tidak lagi menyebut "ADR-0061" di konteks geo	jejak keputusan menunjuk dokumen yang benar	`docs/adr/0068-property-location-precision-and-source.md`	selesai
9 ♦	~~`villa_import.validate_geo_fields` dirujuk tetapi tidak ada~~ **SELESAI 2026-11-13:** aturan hidup di `geo.validate_geo_fields` dan dipanggil **dua** penulis (`villa_import._geo`, `reservation_kernel.upsert_property`); impor CSV menerima empat kolom geo (template 20 kolom)	`VERIFIED` tanpa kedua koordinat atau tanpa kalimat sumber ditolak sebelum menulis; impor ulang tanpa kolom geo tidak menghapus survei	`src/geo.py`, `src/villa_import.py`, `src/reservation_kernel.py`, `tests/test_geo.py`, `tests/test_villa_import.py`	selesai
10 ♦	3 villa pilot semuanya `UNKNOWN` → peta tanpa pin	tamu belum melihat lokasi area villa	DB hidup	Owner (sumber terverifikasi)
11 ♦	~~`SESSION_AUTH.md` menyuruh `--token`; `rotate` hanya menerima `--token` di argumen~~ **SELESAI 2026-11-13:** dokumen memakai `--token-file`; `rotate` menerima `--token-file` (berkas 0600) dan menolak bila dua opsi diberi bersamaan	kebocoran lewat `/proc/<pid>/cmdline` tidak lagi jalan termudah	`docs/security/SESSION_AUTH.md`, `scripts/session_token.py`	selesai
12 ♦	Retensi: D9 = 7 tahun; tabel `RETENTION_AND_INCIDENT_RESPONSE` = 10 tahun untuk booking/audit/kontrak	dua angka untuk satu kebijakan	Bab 20.7	Owner + GM/CEO
13 ♦	Uji restore: `DEPLOYMENT` §5 bulanan vs D10 tiga bulanan	frekuensi tak jelas	Bab 23.5	Owner
14 ♦	Foto situs publik = stok Wikimedia, bukan foto properti	tamu tidak melihat villa sungguhan	Bab 14.2	Owner (lewat `evidence_objects`)
15	D15 (sumber bukti level A) dan D16 (rate card dipublikasikan) OPEN	NON-BLOCKING, tetapi menentukan apa yang boleh dijual/ditampilkan	GO_LIVE	Owner

#	Celah	Dampak	Bukti	Pemegang keputusan
16	Anker audit belum dibuktikan pada mesin ini; backup tidak diperiksa	syarat checklist go-live butir 4–5	preflight WARN	Ops
17	Hosting produksi situs publik: disetujui (ADR-0067), tetapi TLS/nama publik/rate limit jaringan = tugas proxy yang belum dipasang	situs masih loopback	Bab 14.5	Ops
18	Enkripsi at-rest P3 disyaratkan; implementasi bergantung volume/disk	tidak dibuktikan di repo	Bab 20.3	Tech-Security

Risiko metodologis dokumen ini: Bagian II–V diturunkan dari dokumen sumber dan pembacaan kode; setiap angka yang bisa dihitung telah dihitung ulang (Lampiran E memuat daftar yang diverifikasi dan yang hanya dikutip). Dokumen sumber bertanggal (Status-Gap, Alur Kerja) ditandai **[potret]**.

26. Keputusan Owner dan langkah berikutnya

26.1 Keputusan yang menunggu Owner

1. **Koordinat 3 villa pilot:** sumber terverifikasi (kunjungan atau pernyataan tertulis pemilik), presisi (`VERIFIED` atau `AREA_APPROX`), dan teks `geo_source` .
2. ~~ADR peta geo~~ **sudah ditulis 2026-11-13** sebagai ADR-0068 (aturan pembulatan 2 desimal, tiga tingkat presisi, larangan aset remote). Tidak ada lagi yang menunggu Owner di butir ini.
3. **Retensi (Lampiran F butir 5):** satukan D9 (7 tahun) dengan tabel 10 tahun, atau tulis pengecualian per kelas. *Rekomendasi analisis:* untuk **data transaksi, kontrak, pajak, dan audit** pakai **10 tahun** — kewajiban pembukuan/pajak berjalan 10 tahun, dan menghapus pada tahun ke-7 membuat sistem menghapus dokumen yang masih diminta. Angka 7 tahun hanya aman untuk kelas tanpa kewajiban penyimpanan (mis. pesan pemasaran, jejak sesi). Keputusan akhir Owner + counsel; sampai diputuskan, tidak ada pekerjaan penghapusan yang dijalankan.
4. **Frekuensi uji restore (Lampiran F butir 6):** bulanan atau tiga bulanan. *Rekomendasi analisis:* **bulanan** — dengan RPO 24 jam, uji tiga bulanan berarti sampai 90 hari salinan terakhir belum pernah dibuktikan bisa dipulihkan; satu tiket per bulan jauh lebih murah daripada data yang tak teruji.
5. **D15/D16** — apa yang dianggap bukti level A dan rate card apa yang tampil ke tamu.
6. **Urutan pembangunan** Commercial AI dan Warden; Status-Gap §6 menyarankan "jangan membangun Commercial AI sebelum reservation otomatis terbukti".
7. **Foto asli** untuk situs publik.

26.2 Langkah teknis berikutnya (diturunkan dari celah)

Urut	Pekerjaan	Kriteria selesai
1 ✅	Perbarui `docs/security/SESSION_AUTH.md` (`--token-file`) + `rotate --token-file` di `session_token.py` — **selesai 2026-11-13**	opsi argumen token hanya tersisa sebagai kompatibilitas yang didokumentasikan
2 ✅	`validate_geo_fields` + empat kolom geo di `villa_import.py` dan `reservation_kernel.py` — **selesai 2026-11-13**	impor CSV dengan VERIFIED tanpa koordinat/sumber ditolak; tes hijau; `make check` rc=0
3 ✅	ADR-0068 ditulis; label geo di berkas SQL dan tes diperbaiki (komentar saja) — **selesai 2026-11-13**	tak ada label "ADR-0061" pada konteks geo
4 ✅	Audit ulang kategori tes §19 terhadap 105 berkas `test_*.py` — **selesai 2026-11-13**; dihitung per badan fungsi uji, bukan per nama berkas	tabel kategori → berkas: injeksi-sebagai-data 2 berkas/6 uji, penolakan tool 7/15, tenant-IDOR 5/11, handoff 10/43, konkurensi 1/7, privasi-PII 1/16; `grounding` 16/86 dan `retry` / `idempoten` / `replay` 42/302 hanya batas atas (token longgar). Rincian di §3.4 `STATUS_AND_GAP_MAP.md` dan Lampiran G
5	Pasang anker + backup + uji restore di mesin target; ulangi preflight dengan `--anchor-dir` , `--backup`	tak ada WARN anker/backup
6	Pasang reverse proxy TLS + HSTS; jalankan `access_matrix_probe.py` dan `perf_probe.py`	bukti pada berkas laporan
7 ✅	Penjaga rujukan ADR di komentar skema (`tests/test_schema_adr_citations.py`) + `src/schema/README.md` (urutan migrasi, larangan pakai ulang nomor, penjelasan kenapa `009` tidak ada) — **selesai 2026-11-13**	mengembalikan `(ADR-0061)` di baris geo menggagalkan `make check` ; aturan migrasi terbaca tanpa bertanya

26.3 Kriteria sukses proyek (North Star, dari Charter)

0 double booking terkonfirmasi · 100% booking punya policy snapshot + bukti + audit · rekonsiliasi pembayaran ≥ 99% tanpa efek ledger ganda dari retry webhook · 0 klaim material tanpa dukungan dari AI · pilot 10–20 villa (rekomendasi kerja, **bukan** keputusan final: jumlah pasti, staf, tenggat, dan anggaran belum ditetapkan Owner). Dokumen ini **tidak** mengklaim target-target itu tercapai; yang terbukti hari ini adalah gerbang kode (tes, constraint, trigger, pemindai) yang menegakkannya.

LAMPIRAN

Lampiran A — Glosarium

Istilah	Arti di proyek ini
Agency	tenant; perusahaan yang memakai platform, mengisi setelannya sendiri (ADR-0037)
Reservation Kernel	satu-satunya penulis status `HOLD_ACTIVE` / `BOOKING_CONFIRMED` / `BOOKING_CANCELLED`
Hold	penahanan unit sementara; 3 tahap (ADR-0034); `HOLD_REQUESTED` ≠ `HOLD_CONFIRMED`
Policy snapshot	salinan aturan (deposit, batas bayar, pembatalan, pajak) yang terikat pada booking saat dibuat
Evidence level A–D	tingkat bukti ketersediaan; hanya A menutup kedaluwarsa hold dan mengizinkan `can_confirm`
P0–P4	klasifikasi data (Bab 20.1)
Fail-closed	bila ragu/rusak, sistem menolak, bukan menebak
Shadow mode	AI bekerja tanpa efek keluar; hasilnya dibandingkan dengan keputusan manusia (D7)
Anker	sidik jari rantai audit yang diterbitkan ke sistem lain agar penghapusan/penambahan dapat dibuktikan
PBJT	pajak barang/jasa tertentu (hotel/villa) per kabupaten/kota
Merchant of record	pihak yang menerima uang tamu: agency (D1)
RPO/RTO	data maksimum yang boleh hilang / waktu maksimum mati
SLA	janji waktu layanan (`SLA_POLICIES` , `web_v1`)
`UNKNOWN`	presisi geo/ketersediaan tanpa klaim — tidak boleh dijual atau ditampilkan sebagai pasti
Potret	isi dokumen sumber yang bertanggal dan bisa sudah usang

Lampiran B — Indeks 70 ADR

Seluruh 70 berkas berstatus *Accepted*. Dua yang terakhir naik pada 2026-11-13: ADR-0069 (`CONFIRMED` hanya setelah pembayaran terverifikasi dan bukti blok villa — temuan K2, sekaligus keputusan opsi (a) memasukkan empat sisi pembatalan langsung ke graf kanonik) dan ADR-0070 (rupiah adalah nilainya, USD rujukan berlabel). Kedua status itu dibaca `tests/test_adr_status.py` dari tiga ejaan yang pernah dipakai repo. Dibangkitkan dari judul tiap berkas.

No.	Judul
0001	Runtime Storage: SQLite (dev/test) dengan PostgreSQL sebagai target produksi
0002	Okupansi saat Pembatalan Ditinjau dan Sengketa
0003	Master Spec Adoption and Brownfield Strategy
0004	Runtime, API, and Frontend Stack Direction
0005	Identity, Auth, Session, MFA, RBAC, and Scope
0006	Database Migration and Parallel State Strategy
0007	Transactional Outbox, Jobs, and Integration Reliability
0008	Document Storage, Quarantine, and Evidence Security
0009	AI Gateway and Tool Boundaries
0010	Deployment, Observability, and Quality Gates
0011	Production language standard: U.S. English (en-US)
0012	Provider-neutral multi-rail payments
0013	Stablecoin (USDC/USDT) controls
0014	Identifier and human-readable reference format
0015	Inquiry, guest and evidence: domain mapping onto the existing kernel
0016	Matching authority and option sets
0017	The governance policy engine (§16)
0018	The AI service identity and its tool envelope (§18, §56)
0019	Availability state vocabulary and the restricted state
0020	Hold lifecycle: one vocabulary, one writer, and an expiry that is not a release
0021	The check-availability request: a state the platform asks for needs a row to be in
0022	A hold request needs an identity: §56 enforcement on the path that takes inventory out of sale
0023	Publishing the §56 medium-tool allowance: one tool, a bounded window, and no permission in the schema
0024	The §56 enforcement point for presenting an option set, and one gate for every gated path
0025	Quotation versioning, the three snapshots, and the acceptance record (§11)
0026	The discount engine: two funding kinds, two margin guards, one human escape hatch

No.	Judul
0027	A hex digest is not a direct identifier
0028	The approval role `supervisor` is renamed `manager`
0029	The three discount values are published
0030	The absolute margin floor carries a currency
0031	A published rate is one day's price, and the feed that renews it
0032	The last six catalogue keys are published
0033	Guest money enters the agency, and the villa's block proof closes the booking
0034	The three hold stages the business uses, and what each one is in the platform
0035	The human organisation: seven holders, three deferred, two deleted for the AI maker, and a new Greeting Service
0036	Money leaves by a human hand, the account changes by a human hand, and the GM agrees first
0037	The platform is sold per agency: every setting a tenant owns is a setting the tenant fills
0038	An AI agent graduates from shadow mode by measurement, never by mood
0039	A seventh AI agent: the Security & Privacy Warden
0040	Security, safety and privacy come first: the principle, and what enforces it
0041	A failure is routed, counted, and reported: the exception engine
0042	A conversation is one isolated row, and it carries references rather than copies
0043	Escalation silences the AI *before* the human arrives
0044	The escalation vocabulary is closed, the threshold is deny-first, and a handoff needs a staffed role
0045	A capability worker guards the thread, asks the door, then delegates
0046	Pricing is an answer and the offer is one act; the §56 catalogue is not ours to extend
0047	A routine follow-up is a task, and a hold is a slot
0048	The booking status is an answer, and §9's commercial gate has no enforcer yet
0049	The amend/cancel assistant answers and routes; a person decides
0050	The kernel enforces §9's commercial gate: a booking needs the version the guest accepted
0051	The pre-arrival answer assembles what a person sends, and the prep task stays §26's job
0052	§30's closure gate is a blocker list, and it fails closed on facts nobody records
0053	RES-W11 handoff: satu gestur, dua rung, tanpa pintu §56
0054	Daftar dokumen wajib §30 jadi satu policy key milik tenant
0055	Resolusi deposit keamanan jadi fakta berpunya: `deposit_resolutions`
0056	Settlement supplier jadi fakta berpunya: `supplier_settlements` (DUE/PAID)
0057	Telemetri KPI Agent 3: hitungan atas fakta tercatat, tanpa data person
0058	Pengukuran shadow-mode: bar D7 jadi policy key, modul hanya mengukur
0059	Adapter kanal: satu pintu bertanda tangan, pengiriman tetap tindakan manusia
0060	Default mata uang tamu: IDR/USD disimpulkan dari negara asal tamu, hanya tampilan
0061	Efek tool agen telemetri (CT/OPS/FIN): klasifikasi READ, atau tetap di luar gateway
0062	A digit run inside an opaque token is not a direct identifier
0063	A minted id may not be identifier-shaped
0064	Revenue & BI: canonical worker names and the official occupancy denominator
0065	Copy villa publik: menggambarkan wilayah, bukan properti
0066	Dataset demo di-anchor saat seed, bukan tanggal kalender beku
0067	Alamat pengunjung dipercaya hanya dari hop yang ditulis proxy sendiri
0068	Lokasi villa: presisi, sumber, dan satu aturan untuk dua penulis
0069	`CONFIRMED` hanya setelah pembayaran terverifikasi dan bukti blok villa (ACCEPTED 2026-11-13, audit K2; opsi a: empat sisi pembatalan langsung masuk graf)
0070	Rupiah adalah nilainya, USD adalah rujukan berlabel (ACCEPTED 2026-11-13)

Lampiran C — Indeks 59 modul `src/`

Dibangkitkan dari AST: nama berkas, jumlah baris, kalimat pertama docstring modul (— bila tak ada).

Modul	Baris	Docstring modul
`agency_roles.py`	579	A tenant's own role set: rename freely, staff it, and never outrank the blueprint.
`ai_gateway.py`	488	One door for every AI action (§3 / §2A.6), with the §17 ladder deciding how wide it opens.

Modul	Baris	Docstring modul
`ai_service.py`	750	AI service identity and its tool envelope (§18, §56, ADR-0009).
`anchors.py`	485	Publish the audit-chain head outside the database.
`approvals.py`	1556	Human approval queue with dual control for money- and legal-impacting actions.
`audit.py`	935	Append-only, tamper-evident, PII-safe audit trail (`audit_events`).
`availability.py`	399	The canonical availability state (§7, §11, Appendix A).
`booking_closure.py`	553	§30's booking closure gate — the blocker list, computed from the modules that own the facts.
`booking_states.py`	1051	Canonical booking state machine for Villa Agency OS.
`cases.py`	1509	Case lifecycle: guest requests over `cases` , `case_messages` and `case_events` .
`channels.py`	267	§Phase 4's channel adapters — the only door between the outside world and the estate.
`connectors.py`	2553	Kanal masuk/keluar: from channel traffic to cases, and from an approved draft to the wire.
`control_tower.py`	310	AI Control Tower / Orchestrator — Agent 1 of the AI workforce (§7 of V1.1).
`crm.py`	481	CRM: guest master, inquiry intake and confirmed trip requirements (v1.1 §5, §6, §50 WAVE 3).
`dashboard.py`	3292	Internal dashboard — read-only operational views, approval-only write path.
`deposit_resolutions.py`	270	§30's security-deposit resolution — the fact that answers "what happened to the hold".
`discounts.py`	668	The discount engine — §11 Pricing, Quote & Discount; §16 policy; §15 approval; §21 deny.
`documents.py`	1672	Deterministic, identifier-free document issuance on top of `documents` .
`evidence.py`	747	Evidence objects: the quarantine pipeline for files that arrive from outside.
`exception_engine.py`	467	The exception engine: a failure becomes a recorded obligation, exactly once.
`finance_admin.py`	392	Agent 5 — the Finance Admin AI Agent: read-only financial telemetry.
`fx.py`	399	Currency conversion — turning an amount in one currency into another, honestly.
`gates.py`	1492	Fail-closed domain gates for Villa Agency OS.
`geo.py`	418	Where a villa is — and how much of that the public is allowed to know.
`hold_states.py`	128	The canonical hold vocabulary (§7, Appendix A).
`identity.py`	716	Identity: sessions, TOTP enrolment, and step-up (ADR-0005, accepted).
`incidents.py`	1667	Incident management with **deterministic playbooks**.
`intake.py`	1413	Structured intake: deterministic, rule-first extraction of guest requests.
`invoicing.py`	1281	Guest billing — the invoice a stay is settled against.
`marketing_site.py`	1230	Public marketing website: the guest-facing surface of Villa Agency OS.
`matching.py`	1590	Explainable unit matching (Phase 2).
`messages.py`	1661	Grounded outbound message drafts for Villa Agency OS.
`money_display.py`	288	Rupiah-first amounts with an automatic reference conversion (audit 2026-11-13, T8).
`observability.py`	780	Metrics and health for the operations room.
`operations_agent.py`	405	Agent 4 — the Operations AI Agent: workflow telemetry with zero write paths.
`ops_tasks.py`	1524	Operational task queue — `ops_tasks` (Phase 3: jadwal & tugas).
`option_sets.py`	474	Option sets: the villas an agency offers for one inquiry (§5, §34).
`outbox.py`	640	The transactional outbox — a typed letter, written with the state it describes.
`payments.py`	2850	Money movement — hosted payment intents, verified webhooks, the double-entry ledger and reconciliation of the payments that do not match.
`policy_engine.py`	1115	Versioned policy objects — the single home for every business number.
`primitives.py`	771	Shared kernel primitives for Villa Agency OS.
`quotation.py`	821	Quotation versions, their snapshots, and the acceptance (§11).
`quote_calculator.py`	711	Deterministic quote arithmetic.
`references.py`	149	Human-readable references (Master Spec v1.1 Appendix B).
`reservation_kernel.py`	2815	The reservation kernel: holds, bookings and the no-double-booking guarantee.
`reservation_kpi.py`	245	Agent 3's §22 KPI telemetry — the reservation funnel and its governance numbers.
`reservation_service.py`	1651	§9 Agent 3 — the AI Reservation Service: the conversation ledger and the §13 ladder.
`reservation_workers.py`	1602	§9's capability workers — the AI employee's hands, and the only ones it has.
`revenue_bi_agent.py`	448	Agent 6 — the Revenue & BI AI Agent: revenue telemetry with zero write paths.
`roles.py`	299	The human role vocabulary, in one place — ADR-0035 §5, ADR-0036, Master Spec §18.
`scheduler.py`	589	The heartbeat: one tick that charges every deadline in the system.
`schema_loader.py`	849	Schema loading, statement splitting and cross-dialect parity parsing.

Modul	Baris	Docstring modul
`settings.py`	478	Agency settings: the values a **tenant** owns, and whether a tenant is ready to go live.
`shadow_eval.py`	236	§22/D7 shadow-mode measurement — did the agent decide what the human decided?
`supplier_route.py`	664	Supplier route: villa↔supplier relationship, contract versions, rate versions.
`supplier_settlements.py`	261	§30's supplier settlement — what the agency owes, and has paid, the supplier.
`totp.py`	235	TOTP (RFC 6238) and HOTP (RFC 4226) — stdlib only.
`villa_import.py`	552	Bulk inventory import: a tenant's villa list arrives as one file, not two hundred forms.
`villa_showcase.py`	174	Per-villa showcase content for the public marketing surface.

Lampiran D — Migrasi, skrip, dan target make

Berkas `src/schema/`: `001_initial.sql` (+ `.pg.sql`), `002_pg_range_exclusions.pg.sql` (khusus PostgreSQL), `003_policy_catalogue_and_deny_registry`, `004_currency_aware_margin_floor`, `005_fx_rate_max_age_hours`, `006_outbox_and_integration_inbox`, `007_exception_fingerprints`, `008_agency_settings`, `010_agency_roles`, `011_ai_ladder`, `012_reservation_service`, `013_deposit_resolutions`, `014_supplier_settlements`, `015_shadow_bars`, `016_guest_preferred_currency`, `017_property_geo`. **Nomor 009 tidak ada** sebagai berkas — dijelaskan 2026-11-13 di `src/schema/README.md`: riwayat git membuktikan `009_*.sql` tidak pernah ada dan tidak ada migrasi yang dihapus, jadi nomor itu dilompati sejak awal dan tidak boleh dipakai ulang (lihat Lampiran F butir 9).

`scripts/` (24 berkas + `__pycache__`): `access_matrix_probe`, `ai_mode`, `apply_migrations`, `audit_structure`, `build_deliverables`, `closure_facts`, `generate_pg_twin`, `go_live_smoke`, `import_villas`, `manage_roles`, `perf_probe`, `phishing_drill_score`, `pii_scan`, `preflight`, `publish_ai_allowance`, `publish_anchor`, `publish_policy_value`, `refresh_fx_rate`, `render_az_doc`, `reservation_kpi`, `secret_scan.sh`, `seed_demo`, `session_token`, `unsafe_config_scan.sh`.

Target make: `test verify syntax lint secret-scan unsafe-scan pii-scan check interpreter schema-parity pg-twin anchor-publish anchor-verify allowance-status policy-status migrate-check render-az audit-structure` (daftar `.PHONY` di `Makefile`; `make help` mencetak deskripsinya).

Lampiran E — Apa yang diverifikasi dan apa yang hanya dikutip

Dihitung/dibaca ulang dari repo/DB pada 2026-11-12 (dan 2026-11-13 untuk: 58/58 modul `src/` berhasil diimpor pada 3.14.9; isi `src/schema/README.md`; riwayat `git log --all -- src/schema/009*` yang kosong; byte vs karakter `STATUS_AND_GAP_MAP.md`; dan, diukur ulang 2026-11-13: 72 tabel/62 indeks/64 trigger/106 enum**/77 `INSERT` seed pada model skema, 183 indeks DB hidup (122 `sqlite_autoindex`), 103 berkas `test_*.py` (57.723 baris, dihitung pada `1c0dd2f` yang sama),** 187 komit pada commit `1c0dd2f` **— dihitung pada SHA itu supaya angkanya stabil, bukan bergeser tiap kali ada commit dokumen):** jumlah komit dan komit pertama; jumlah modul/baris `src/`; berkas dan baris tes; jumlah ADR dan status; `PAGE_ROLES` (14 entri) dan 6 peran; 73 nama tabel §9.2 vs `sqlite_master` DB hidup (73/73 cocok; 72 tabel model + `schema_migrations`); nama tabel/kolom Bab 13 (semua ada, kecuali `approvals` yang adalah modul); 14 baris `schema_migrations`; 3 properti `UNKNOWN`; keluaran preflight; target make; isi `GO_LIVE_DECISIONS.md`; CSP/rate limit/honeypot/token form pada `marketing_site.py`; keberadaan/ketiadaan `validate_geo_fields`; rujukan "ADR-0061".

Dikutip dari dokumen sumber (tidak diuji ulang di sini): angka SLA/retensi/RPO-RTO; isi 6 playbook insiden; ambang shadow-mode (agreement ≥ 95%, ≥ 100 kasus); ukuran performa (3,42 ms, 292 req/s, 20 pengunjung 1.248,2→74,3 ms); hasil uji interpreter 3.11/3.12 (3.14 sudah diukur ulang ke 3.14.9, impor saja); census dependency (dikutip, lalu **dikoreksi** 2026-11-13: bukan "0" mutlak — `psycopg` / `psycopg2` diimpor lazy di jalur PostgreSQL); daftar 27 `denied_actions`; isi tabel §9 selain nama tabel.

Tidak dilakukan: uji penetrasi; verifikasi legal/pajak; memulihkan backup; menjalankan tes PostgreSQL hidup.

Lampiran F — Daftar ketidakkonsistenan yang ditemukan

#	Temuan	Lokasi	Tindakan yang disarankan	Status 2026-11-13
1	Label "ADR-0061" pada peta geo salah; ADR-0061 = efek tool agen telemetri (opsi B)	`001_initial.sql:53`, `001_initial.pg.sql:53`, `017_property_geo.sql:1`	tulis ADR peta; ganti komentar	✅ ditutup — ketiga berkas menyebut ADR-0068; dikunci `tests/test_schema_adr_citations.py` (gagal bila ADR-0061 muncul lagi di baris geo)
2	`villa_import.validate_geo_fields` dirujuk tetapi tidak ada	`017_property_geo.sql:20`	bangun fungsi + tes, atau hapus rujukan	✅ ditutup — fungsi ada di `src/geo.py`, dipanggil jalur impor & kernel
3	`SESSION_AUTH.md` menyebut `--token` pada dashboard	§1, §4	ganti `--token-file`	✅ ditutup — `--token-file <path>`
4	`session_token.py rotate --token <lama>` menaruh token sesi di argumen	`session_token.py:224`	nilai risikonya; bila perlu baca dari stdin/berkas	✅ ditutup — `rotate --token-file`; `--token` dipertahankan, keduanya bersamaan → exit 2

#	Temuan	Lokasi	Tindakan yang disarankan	Status 2026-11-13
5	Retensi 7 tahun (D9) vs 10 tahun (tabel retensi)	GO_LIVE D9 vs RETENTION	keputusan Owner	⏳ **menunggu Owner + counsel** — D9 "hapus setelah 7 tahun" bertentangan dengan `RETENTION` (data transaksi 10 tahun) dan dengan aturan pembukuan/pajak 10 tahun; sistem menjalankan aturan yang disetujui, jadi angkanya harus dipilih Owner, bukan diambil dari salah satu dokumen
6	Uji restore bulanan vs tiga bulanan	DEPLOYMENT §5 vs D10	keputusan Owner	⏳ **menunggu Owner** — `DEPLOYMENT` §5 menulis "uji restore penuh **bulanan**", D10 menulis "tiap **3 bulan**"; RPO 24 jam / RTO 4 jam sama di kedua dokumen. Calon jawaban: satukan ke **bulanan** (lebih ketat, biayanya satu tiket operasional per bulan)
7	Status-Gap §3.5 menyatakan traceability belum ada; berkasnya ada	STATUS_AND_GAP_MAP	tandai usang	✅ ditutup — penanda **USANG sejak 2026-09-28** dipasang di §3.5 (berkas `docs/AI_WORKFORCE_TRACEABILITY.md`, 23.149 byte, 6 judul `##` + 16 judul `#`; angka "24 bagian" di dalamnya = 24 bagian dokumen AI Workforce V1.1, bukan jumlah bagian berkasnya); paragraf lama disimpan sebagai potret sejarah
8	Census 57 modul (SCALING_AND_UPGRADE) vs 58 hari ini	SCALING §1	perbarui angka	✅ ditutup — §1 kini "58 modul"; tabel kompatibilitas diperbarui ke **3.14.9, 58/58 modul berhasil diimpor** (diukur ulang 2026-11-13). Sekalian dikoreksi: klaim "0 dependency pihak ketiga" tidak utuh — `psycopg` v3/`psycopg2` diimpor *lazy* di `schema_loader.connect_postgres` untuk kembaran PostgreSQL
9	Tidak ada migrasi bernomor 009	`src/schema/`	jelaskan atau catat sengaja	✅ ditutup — `src/schema/README.md`: riwayat git membuktikan `009_*.sql` **tidak pernah ada** dan tidak ada migrasi yang dihapus (`git log --all -- 'src/schema/009*'` kosong; `--diff-filter=D` kosong); dilompati sejak awal, nomor tidak dipakai ulang
10	Status-Gap §1 menulis go-live NO-GO (D17 OPEN); hari ini D17 DECIDED dan preflight GO	STATUS_AND_GAP_MAP	tandai potret (sudah)	✅ sudah berupa potret — banner "CATATAN STATUS (2026-10-03) — baca ini dulu" di baris 4, jadi `NO-GO` di sana dibaca sebagai keadaan 2026-10-02, bukan hari ini
11	Ukuran `STATUS_AND_GAP_MAP.md` terukur berbeda pada dua pembacaan (25.677 vs 25.871 vs 24.308 karakter) — perbedaan byte vs karakter	—	tidak diselidiki lebih jauh	✅ diselidiki — ukuran berkas dihitung **byte**; isi dihitung **karakter**. Satu pembacaan 2026-11-13: `wc -c` 25.386 byte vs `wc -m` 24.983 karakter (selisih 403 = karakter non-ASCII multi-byte). Kedua angka benar bila satuannya disebut; setiap pembacaan setelah dokumen disunting akan bergeser, jadi ukuran berkas tidak boleh dipakai sebagai bukti isi

Ringkasan Lampiran F (2026-11-13): 9 dari 11 butir ditutup dengan bukti di repo; 2 butir (retensi data, frekuensi uji restore) **tidak bisa ditutup oleh kode** karena keduanya keputusan bisnis yang bertentangan antardokumen — keduanya menunggu Owner, dan sampai diputuskan sistem **tidak** boleh menegakkan salah satunya diam-diam. Butir 5 membawa risiko kepatuhan (menghapus data transaksi pada tahun ke-7 sementara kewajiban pembukuan/pajak berjalan 10 tahun), jadi ia didahulukan sebelum ada penghapusan data nyata. Butir 1 kini punya penjaga otomatis: komentar skema yang menyebut ADR yang salah menggagalkan `make check`, bukan menunggu audit berikutnya.

Lampiran G — Bukti konkurensi & sensus angka (diukur 2026-11-13)

Lampiran ini menjawab keberatan yang paling mudah ditutupi kata: klaim "0 confirmed double booking" hanya bermakna kalau ada uji yang **bisa gagal** saat jaminannya dicabut. Semua angka di bawah dihitung dari repo/DB pada 2026-11-13, bukan dikutip.

Yang diukur	Angka	Cara ukur
Uji balapan nyata	`tests/test_no_double_booking_concurrency.py` — 272 baris, 7 uji	`wc -l`; `grep -cE '^\s+def test_'`
Basis uji	DB **file-backed** + `BEGIN IMMEDIATE` + partial unique index `uq_holds_active_slot`; 2–3 penulis nyata disinkronkan `threading.Barrier`	baca `src/reservation_kernel.py`, `src/schema/001_initial.sql`, isi uji
Alasan `:memory:` ditolak	setiap koneksi `sqlite3` mendapat database privat → tidak ada balapan → uji "satu pemenang" lulus secara hampa	`docs/DOUBLE_BOOKING_EVIDENCE.md`
Kontrol positif	dua unit berbeda, dua penulis → dua-duanya sukses (membuktikan harness memang paralel)	uji `TestDifferentUnitsDoNotInterfere`
Kontrol negatif	pada salinan terpisah: `BEGIN IMMEDIATE` → `BEGIN`, guard overlap dilewati, index dihapus → uji **gagal** (bukti uji tidak hampa)	`/tmp/negctl` (salinan, bukan repo kerja)
Stabilitas	1×, 5×, 12×, 20×, 20×, 10× run berulang; tiap run `7 passed`	log run; `pytest.ini` tanpa `addopts` penutup kegagalan
Model skema	**72 tabel · 62 indeks · 64 trigger · 106 enum · 77 baris INSERT**	`schema_loader.parse_schema_model('sqlite')` + regex `src/schema/*.sql` (dua sumber independen)
Berkas uji	`tests/test_*.py` **105 berkas / 58.176 baris**; seluruh `.py` di `tests/` **107 / 58.352**	`git ls-tree` + `wc -l` per berkas

Yang diukur	Angka	Cara ukur
Fungsi uji	**2.735** `def test_`	`grep -rhcE '^\s+def test_' tests/test_*.py`
Berkas ter-track	**388**	`git ls-files | wc -l` pada komit rilis ini
Kategori uji (per badan fungsi)	concurrency 1/7 · tenant-IDOR 5/11 · penolakan tool 7/15 · injeksi-sebagai-data 2/6 · handoff 10/43 · `grounding` 16/86 dan `retry` / `idempoten` / `replay` 42/302 (**batas atas, token longgar**)	skrip klasifikasi `re.split` per `def test_`

Batas yang tetap harus dikatakan: uji ini **antar-thread dalam satu proses pada satu berkas** (bukan antar-host), hanya SQLite (twin PostgreSQL diuji terpisah oleh target `pg-twin`), dan tidak mengukur kinerja. Yang dibuktikan adalah **kebenaran** (satu slot, satu pemegang), bukan kemustahilan mutlak di semua topologi.